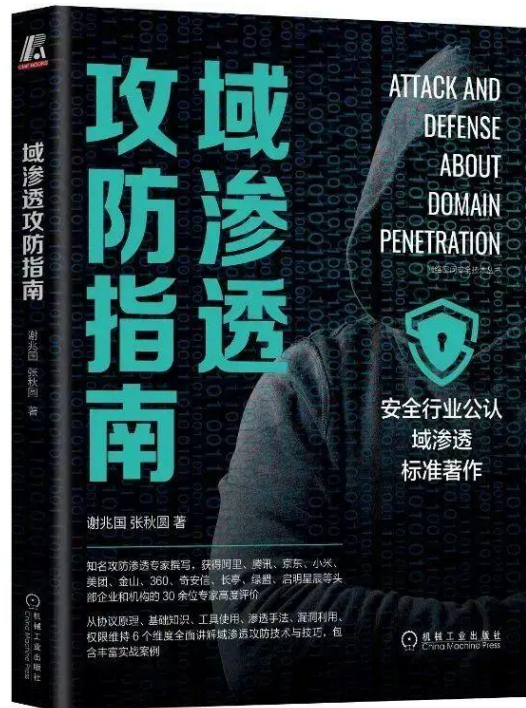


本地帐户和活动目录帐户

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

在学习域的过程中，我们经常会听到各种各样的帐户，如：本地帐户、域帐户、服务帐户和机器帐户。那么这些帐户与我们之前在工作组中所知的帐户有什么区别和联系呢？

本章主要讲解这几种帐户的特点和联系等。

本地帐户 Local Accounts

本地帐户 Local Accounts 存储在本地的服务器上。这些帐户可以在本地服务器上分配权限，但只能在该服务器上分配。默认的本地帐户是内置帐户(如 administrator、guest 等)，在安装 Windows 时自动创建。Windows 安装后，无法删除默认的本地帐户。此外，默认的本地帐户不提供对网络资源的访问。默认的本地帐户用于根据分配给该帐户的权限来管理对本地服务器资源的访问。默认的本地帐户和后期创建的本地帐户都位于“用户”文件夹中。

1. administrator

在 Windows 安装过程中创建的第一个帐户就是 administrator 帐户，其 SID 为：S-1-5-21-XX-500。该帐户也是默认的本地管理员帐户，在本地管理员组 administrators 中。该帐户可以完全控制服务器，并根据需要向用户分配用户权限和访问控制权限。每台机器都有该帐户，不能删除或锁定默认的 administrator 管理员帐户，但可以重命名或禁用它。如图所示：

```
C:\Windows\system32>wmic useraccount get name,sid
Name                SID
Administrator       S-1-5-21-2110760149-2411624824-3966648303-500
DefaultAccount       S-1-5-21-2110760149-2411624824-3966648303-503
Guest                S-1-5-21-2110760149-2411624824-3966648303-501
WDAGUtilityAccount   S-1-5-21-2110760149-2411624824-3966648303-504
xie                  S-1-5-21-2110760149-2411624824-3966648303-1000

C:\Windows\system32>net localgroup administrators
Alias name    administrators
Comment      Administrators have complete and unrestricted access to the computer/domain

Members

-----
Administrator
xie
The command completed successfully.

C:\Windows\system32>net user administrator /del
System error 1371 has occurred.
Cannot perform this operation on built-in accounts.
```

不能删除默认的 administrator 账户

注：即使重命名 administrator 帐户，其 SID 也是不变的。

为了安全考虑，在高版本的 Windows 系统中，Windows 默认将禁用内置的管理员帐户 administrator，并创建作为管理员组 administrators 成员的另一个本地帐户。管理员组的成员可以运行具有提升权限的应用程序，而不使用“运行为管理员”选项。如图所示，可以看到 administrator 帐户的激活属性为 No。

```
C:\Users\xie>net user administrator
User name                Administrator
Full Name
Comment                  Built-in account for administering the computer/domain
User's comment
Country/region code      000 (System Default)
Account active            No
Account expires           Never

Password last set        8/27/2021 10:41:38 AM
Password expires         Never
Password changeable      8/27/2021 10:41:38 AM
Password required        No
User may change password Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               Never

Logon hours allowed      All

Local Group Memberships  *Administrators
Global Group memberships *None
The command completed successfully.
```

如果想激活默认的 administrator 帐户的话，可以以管理员权限打开 cmd 窗口执行如下命令：

```
net user administrator /active:yes
```

如图所示，执行命令激活 administrator 帐户。

```
C:\Windows\system32>net user administrator /active:yes
The command completed successfully.

C:\Windows\system32>net user administrator
User name                Administrator
Full Name
Comment                  Built-in account for administering the computer/domain
User's comment
Country/region code      000 (System Default)
Account active            Yes
Account expires           Never

Password last set        8/27/2021 10:41:38 AM
Password expires         Never
Password changeable      8/27/2021 10:41:38 AM
Password required        No
User may change password Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               Never

Logon hours allowed      All

Local Group Memberships  *Administrators
Global Group memberships *None
The command completed successfully.
```

管理员帐户为用户提供了对本地服务器上的文件、目录、服务和其他资源的完全访问权限。管理员帐户可用于创建本地用户，并分配用户权限和访问控制权限。管理员还可以通过简单地更改用户权限和权限来随时控制本地资源。虽然文件和目录可以暂时不受管理员帐户的保护，但管理员帐户可以随时通过更改访问权限来控制这些资源。

(1) 域内计算机上的本地 administrator

机器在加入域后，本地 administrator 帐户属性不变。如果选择以本地 administrator 帐户登录的话，需要加上本机机器名作为前缀以本地身份登录。

如图所示，机器主机名为 win2012r2，以本地 administrator 身份登录该机器。



以本地管理员身份登录后，无法通过 SAMR 协议查询 LDAP 相关信息。如图所示：

```
C:\Users\Administrator>whoami
win2012r2\administrator

C:\Users\Administrator>net user /domain
The request will be processed at a domain controller for domain xie.com.

System error 5 has occurred.

Access is denied.
```

如果想通过 SAMR 协议查询 LDAP 信息的话，必须先用工具提升到 System 权限，再执行查询操作。至于为什么需要提升到 System 权限后去查询，会在下面的机器帐户篇中讲解。

如图所示，将权限提升为 System 后，再通过 SAMR 协议查询 LDAP 相关信息。

```
C:\Users\Administrator\Desktop>psexec.exe -s cmd.exe
```

```
PsExec v2.2 - Execute processes remotely  
Copyright (C) 2001-2016 Mark Russinovich  
Sysinternals - www.sysinternals.com
```

```
Microsoft Windows [版本 6.3.9600]  
(c) 2013 Microsoft Corporation。保留所有权利。
```

```
C:\Windows\system32>whoami  
nt authority\system
```

```
C:\Windows\system32>net user /domain  
这项请求将在域 xie.com 的域控制器处理。
```

```
\\DC.xie.com 的用户帐户
```

Administrator	Guest	hack
krbtgt	test	

命令运行完毕，但发生一个或多个错误。

2. Guest

在 Windows 安装过程中会创建 Guest 帐户，其 SID 为：S-1-5-21-XX-501，但是该帐户默认是禁用的。Guest 帐户允许在计算机上没有帐户的临时或一次性用户临时登录本地服务器或客户端计算机。默认情况下，Guest 帐户的密码为空。因为 Guest 帐户可以提供匿名访问，因此这是一个安全风险。所以为了安全起见，最好是禁用来宾帐户。如图所示，可以看到 Guest 帐户默认是禁用的。

```
net user guest
```

```
C:\>net user guest
User name                Guest
Full Name
Comment                  供来宾访问计算机或访问域的内置帐户
User's comment
Country/region code      000 (System Default)
Account active           No
Account expires          Never

Password last set        2022/1/20 16:42:22
Password expires         Never
Password changeable      2022/1/21 16:42:22
Password required        No
User may change password No

Workstations allowed     All
Logon script
User profile
Home directory
Last logon              Never

Logon hours allowed      All

Local Group Memberships  *Guests
Global Group memberships *None
The command completed successfully.
```

默认情况下，Guest 帐户是默认本地 Guests 组(SID: S-1-5-32-546)的唯一成员，它允许用户登录到服务器。如图所示，可以看到 Guest 用户属于 Guests 组。

```
net localgroup Guests
```

```
wmic group get name,sid | findstr Guests
```

```
C:\>net localgroup Guests
Alias name     Guests
Comment       按默认值，来宾跟用户组的成员有同等访问权，但来宾帐户的限制更多

Members

-----
Guest
The command completed successfully.

C:\>wmic group get name,sid | findstr Guests
Guests          S-1-5-32-546
```

3. DefaultAccount

DefaultAccount 也被称为默认系统管理账户 DSMA，该帐户是在 Windows 10 版本 1607 和 Windows Server2016 中引入的内置帐户。DSMA 是一种著名的用户帐户类型，它是一个用户中立的帐户，可以用于运行多用户感知或与用户无关的进程。DSMA 在桌面 SKU 和 WS2016 上默认被禁用。

如图所示，可以看到 DefaultAccount 帐户默认被禁用了。

```
net user DefaultAccount
```



```
C:\>net user DefaultAccount
User name                DefaultAccount
Full Name
Comment                  系统管理的用户帐户。
User's comment
Country/region code      000 (System Default)
Account active            No
Account expires           Never

Password last set        2022/1/20 16:34:16
Password expires         Never
Password changeable      2022/1/21 16:34:16
Password required        No
User may change password  Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               Never

Logon hours allowed      All

Local Group Memberships  *系统管理的帐户组
Global Group memberships *None
The command completed successfully.
```

DSMA 有一个著名的 RID 为 503，因此，DSMA 的安全标识符 SID 具有如下格式的著名 SID：S-1-5-21-xx-503。

如图所示，可以看到 DefaultAccount 帐户的 SID。

```
wmic useraccount get name,sid
```



```
C:\>wmic useraccount get name,sid
Name                SID
Administrator       S-1-5-21-540866534-4101927680-2958546539-500
DefaultAccount       S-1-5-21-540866534-4101927680-2958546539-503
Guest                S-1-5-21-540866534-4101927680-2958546539-501
```

DSMA 是著名的 System Managed Accounts Group 组的成员，该组拥有著名的 SID: S-1-5-32-581。如图所示，可以看到 DefaultAccount 帐户属于 System Managed Accounts Group 组。

```
net localgroup "System Managed Accounts Group"
wmic group get name,sid | findstr "System Managed Accounts Group"
```

```
C:\>net localgroup "System Managed Accounts Group"
Alias name           System Managed Accounts Group
Comment             此组的成员由系统管理。

Members

-----
DefaultAccount
The command completed successfully.

C:\>wmic group get name,sid | findstr "System Managed Accounts Group"
System Managed Accounts Group      S-1-5-32-581
```

4. WDAGUtilityAccount

WDAGUtilityAccount 帐户是 Windows 系统为 Windows Defender 应用程序防护方案管理和使用的用户帐户，该帐户是在 Windows 10 版本 1709 和 Windows Server 2019 中引入的内置帐户。除非在设备上启用了应用程序防护，否则它默认保持禁用状态。WDAGUtilityAccount 用于以具有随机密码的标准用户登录应用程序防护容器。如图所示，可以看到 WDAGUtilityAccount 其激活状态为 No。

```
net user WDAGUtilityAccount
```

```

C:\>net user WDAGUtilityAccount
User name                WDAGUtilityAccount
Full Name
Comment                  系统为 Windows Defender 应用程序防护方案管理和使用的用户帐户。
User's comment
Country/region code      000 (System Default)
Account active            No
Account expires           Never

Password last set        2021/1/30 9:38:44
Password expires         Never
Password changeable      2021/1/31 9:38:44
Password required        Yes
User may change password Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               Never

Logon hours allowed      All

Local Group Memberships
Global Group memberships *None
The command completed successfully.

```

WDAGUtilityAccount 有一个著名的 RID 为 504，因此，WDAGUtilityAccount 的安全标识符 SID 具有以下格式的著名 SID：S-1-5-21-xx-504。

如图所示，可以看到 WDAGUtilityAccount 的 SID。

wmic useraccount get name,sid

```

C:\>wmic useraccount get name,sid
Name                SID
Administrator       S-1-5-21-540866534-4101927680-2958546539-500
DefaultAccount       S-1-5-21-540866534-4101927680-2958546539-503
Guest                S-1-5-21-540866534-4101927680-2958546539-501
hack                 S-1-5-21-540866534-4101927680-2958546539-1001
WDAGUtilityAccount   S-1-5-21-540866534-4101927680-2958546539-504

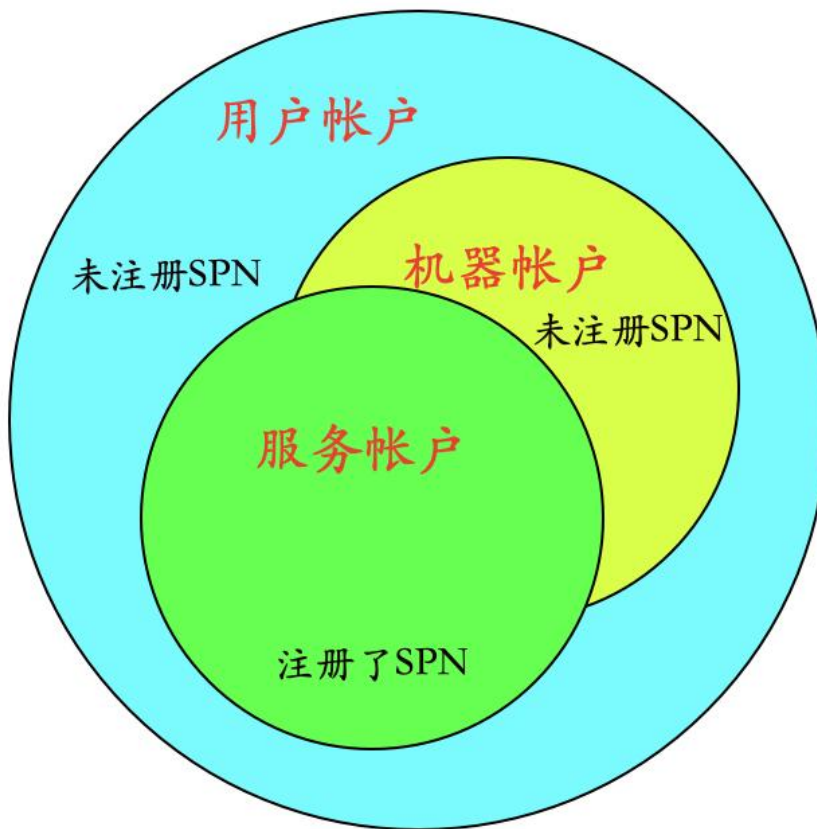
```

活动目录帐户 Active Directory Accounts

活动目录帐户是活动目录中的帐户，活动目录帐户可分为用户帐户、服务帐户和机器帐户。活动目录帐户存储在活动目录数据库中。

从图中我们可以看到用户帐户、服务帐户和机器帐户之间的包含关系。不管服务帐户还是机器帐户，其实都属于用户帐户。而区分服务帐户的一点就是看其是否注册了 SPN。区分机器帐户的一点就是看其 objectcategory 属性是否为 computer。

活动目录帐户



下面我们来看看这几种活动目录帐户的区别和联系。

1. 用户帐户 User Accounts

活动目录用户帐户可以代表一个物理实体，如个人。用户帐户就是在域内的用户帐户，与本地用户帐户存储在本地机器不同的是，域用户帐户存储在活动目录数据库中。域内所有用户均在域全局组 Domain Users 内。

如图所示，是 Domain Users 组的属性。

Domain Users 属性
?
x

常规
成员
隶属于
管理者


Domain Users

组名(Windows 2000 以前版本)(W):

描述(E):

电子邮件(M):

组作用域

☐ 本地域(O)
☒ 全局(G)
☐ 通用(U)

组类型

☒ 安全组(S)
☐ 通讯组(B)

注释(N):

确定

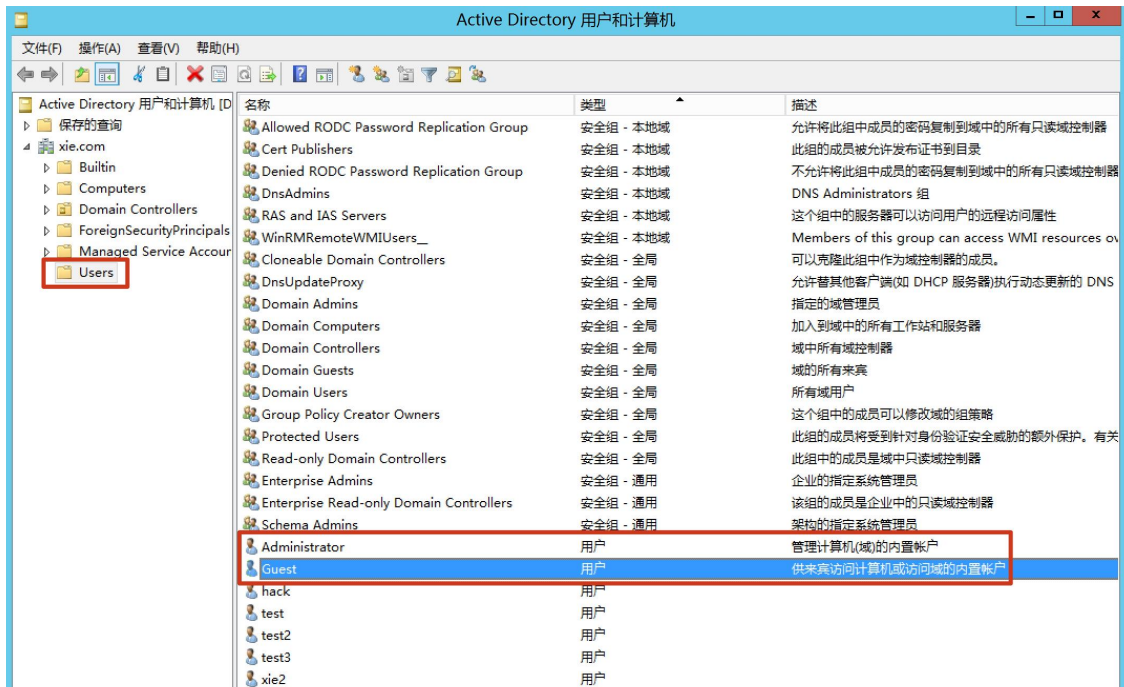
取消

应用(A)

(1) 域控上的本地账户

服务器在升级为域控后，其本地帐户会在活动目录中有对应的帐户，它们将存储在活动目录用户和计算机中的“Users”容器中。如本地的 Guest 帐户将提升为域的 Guest 帐户、本地 administrator 帐户将提升为域的 administrator 帐户。

如图所示，可以看到本地的 administrator 帐户和本地 Guest 帐户都在“Users”容器中，提升为了域内的帐户。



服务器在升级为域控后，其本地普通用户将变为域普通用户，其本地管理员组 administrators 内的用户将升级为域管理员组 Domain Admins 内的用户，默认本地管理员 administrator 将升级为域默认管理员 administrator，并需要设置符合密码强度的密码。此后，这些帐户具有域范围的访问权限，访问时加上域前缀即可，并且与域内机器或独立服务器的默认本地用户帐户完全独立。

(2) administrator 帐户

服务器在升级为域控后，本地 administrator 帐户将升级为域 administrator 帐户，其是活动目录中的 Administrators、Domain Admins、Enterprise Admins、组策略创建者所有者和 Schema Admins groups 的默认成员。

如图所示，是域管理员 administrator 的一些属性，其 SID 为 S-1-5--500。

Administrator account attributes

Attribute	Value
Well-Known SID/RID	S-1-5-<domain>-500
Type	User
Default container	CN=Users, DC=<domain>, DC=
Default members	N/A
Default member of	Administrators, Domain Admins, Enterprise Administrators, Domain Users. Note that the Primary Group ID of all user accounts is Domain Users. Group Policy Creator Owners, and Schema Admins in Active Directory Domain Users group
Protected by ADMINSDHOLDER?	Yes
Safe to move out of default container?	Yes
Safe to delegate management of this group to non-service administrators?	No

(3) Guest 帐户

服务器在升级为域控后，本地 Guest 帐户将升级为域 Guest 帐户。其是针对没有个人帐户的人的用户帐户。此用户帐户不需要密码。默认情况下，Guest 帐户被禁用，建议保持禁用。

如图所示，是域 Guest 帐户的一些属性，其 SID 为 S-1-5--501。

Guest

Attribute	Value
Well-Known SID/RID	S-1-5-<domain>-501
Type	User
Default container	CN=Users, DC= <domain>, DC=
Default members	None
Default member of	Domain Guests, Guests
Protected by ADMINSDHOLDER?	No
Safe to move out of default container?	Can be moved out, but it is not recommended.
Safe to delegate management of this group to non-Service admins?	No
Notes	A user account for people who do not have individual accounts. This user account does not require a password. By default, the Guest account is disabled, and it is recommended that it stay disabled. You can set rights and permissions for the Guest account just like any user account. By default, the Guest account is a member of the built-in Guests group and the Domain Guests global group, which allows a user to log on to a domain.

如图所示，我们在域控上激活 Guest 用户。

```
C:\Users\Administrator>net user guest /active:yes
The command completed successfully.
```

如图所示，激活完成后，该 Guest 用户将可以登录域内所有成员机器。

```
PS C:\Users\Guest> whoami
xie\guest
```

(4) krbtgt 帐户

krbtgt 帐户是一个本地默认帐户，其作用为密钥发行中心服务帐户，它会在创建新域时自动创建。

如图所示，是 krbtgt 用户的信息。

```
C:\Users\Administrator>net user krbtgt
User name                krbtgt
Full Name
Comment                  密钥发行中心服务帐户
User's comment
Country/region code      000 (System Default)
Account active            No
Account expires           Never

Password last set        2021/10/16 11:26:55
Password expires         2024/7/11 11:26:55
Password changeable      2021/10/17 11:26:55
Password required        Yes
User may change password  Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               Never

Logon hours allowed      All

Local Group Memberships  *Denied RODC Password
Global Group memberships *Domain Users
The command completed successfully.
```

如图所示，任何情况下无法删除此帐户，无法更改该帐户的名称，也无法在活动目录中启用 krbtgt 帐户。

```
C:\Users\Administrator>net user krbtgt /del
System error 1371 has occurred.

Cannot perform this operation on built-in accounts.

C:\Users\Administrator>net user krbtgt /active:yes
System error 1371 has occurred.

Cannot perform this operation on built-in accounts.
```

krbtgt 有一个著名的 RID 为 502，因此，krbtgt 的安全标识符 SID 具有以下格式的著名 SID：S-1-5--502。如图所示，是域 krbtgt 帐户的一些属性。

KRBTGT account attributes

For details about the KRBTGT account attributes, see the following table.

Attribute	Value
Well-Known SID/RID	S-1-5-<domain>-502
Type	User
Default container	CN=Users, DC=<domain>, DC=
Default members	None
Default member of	Domain Users group. Note that the Primary Group ID of all user accounts is Domain Users.
Protected by ADMINSDHOLDER?	Yes
Safe to move out of default container?	Can be moved out, but we do not recommend it.
Safe to delegate management of this group to non-Service admins?	No

krbtgt 帐户是 krbtgt 安全主体的实体。在 Kerberos 身份验证的 AS-REP 步骤中，KDC 返回的 TGT 认购权证是由 krbtgt 用户哈希加密的，而 krbtgt 帐户的哈希只有 KDC 知道。详情可以看 1.2 章中的 Kerberos 协议篇。

(5) 新建域用户

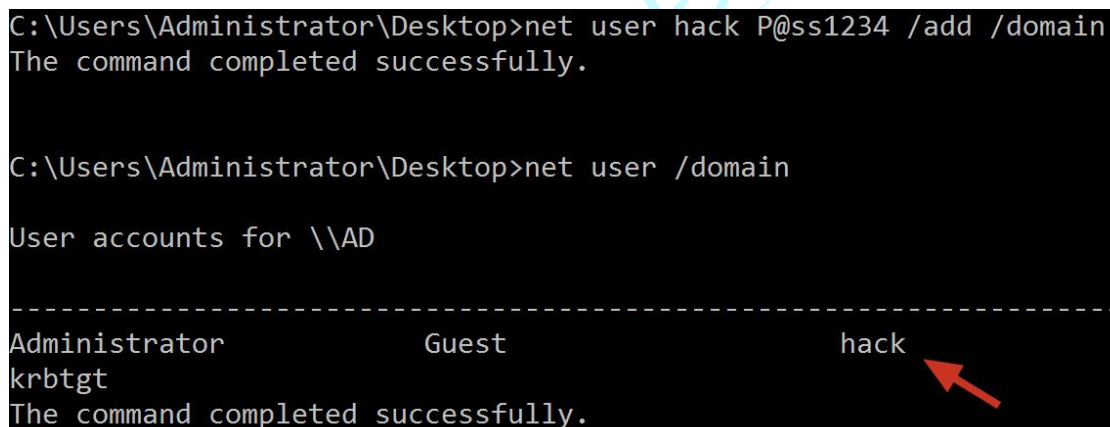
在域内，只有域管理员和企业管理员有权限新建域帐户。新建域帐户可以采用命令行方式创建也可以采用图形化方式创建。新建后的域帐户均在 Domain Users 组中。

命令行新建域用户

如下命令，创建域帐户 hack，密码为 P@ss1234。

```
net user hack P@ss1234 /add /domain
```

如图所示，成功新建域用户 hack。



```
C:\Users\Administrator\Desktop>net user hack P@ss1234 /add /domain
The command completed successfully.

C:\Users\Administrator\Desktop>net user /domain

User accounts for \\AD

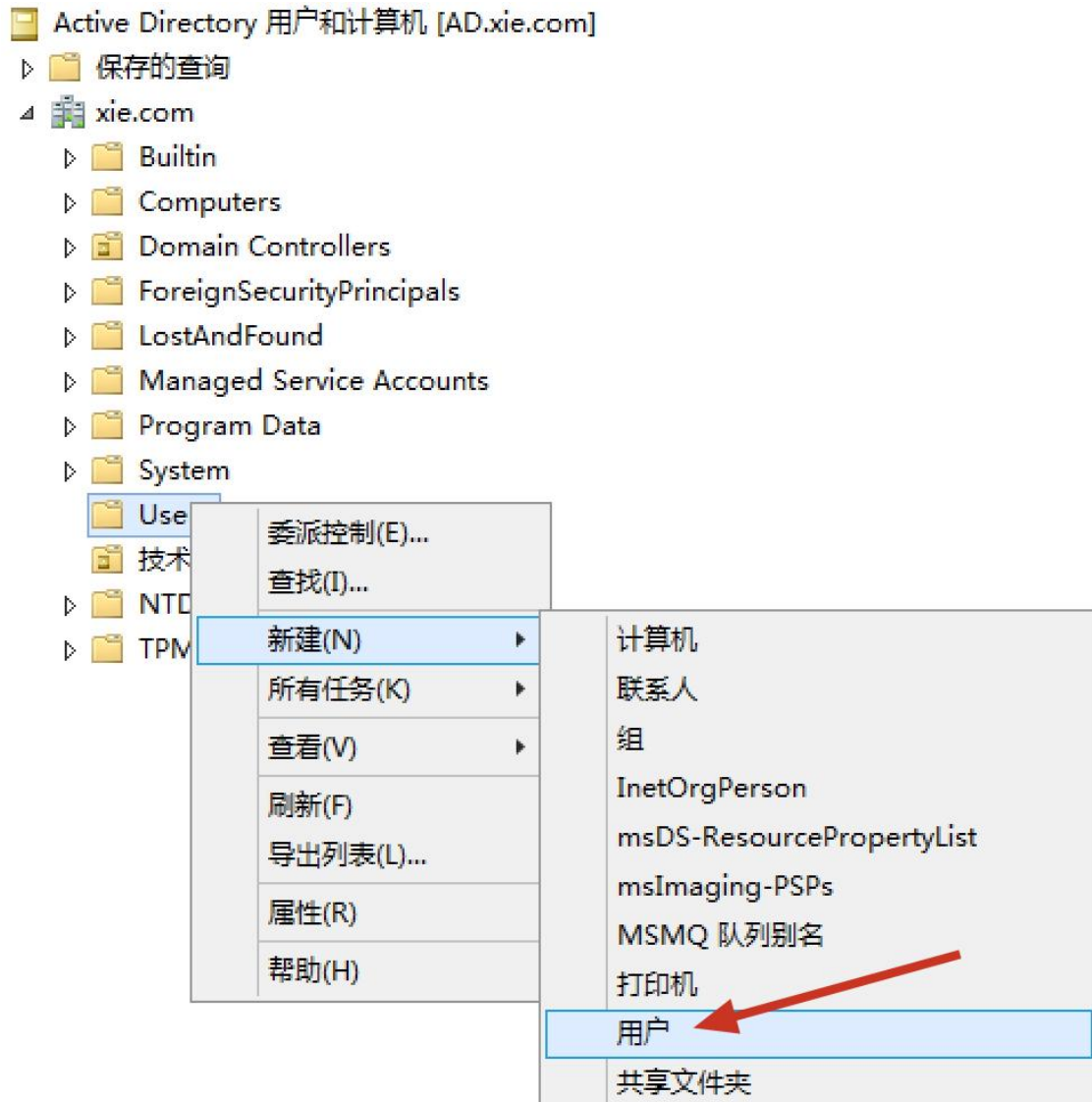
-----
Administrator          Guest                  hack
krbtgt
The command completed successfully.
```

The screenshot shows a Windows command prompt window. The first command executed is `net user hack P@ss1234 /add /domain`, which returns `The command completed successfully.`. The second command is `net user /domain`, which lists the user accounts for the domain. The output shows a table with three columns: `Administrator`, `Guest`, and `hack`. The `hack` user is highlighted with a red arrow. Below the table, the text `krbtgt` is displayed, followed by `The command completed successfully.`

图形化界面新建域用户

域管理员可以打开 Active Directory 用户和计算机管理框来创建用户。

如图所示，直接在 Users 容器右键——>新建——>用户即可。



如图所示，弹出如下对话框，只需要填姓名和用户登录名那里即可，姓、名以及英文缩写可填可不填，然后点击下一步。

fcmit.cc

新建对象 - 用户

创建于: xie.com/

姓(L):

名(F): 英文缩写(I):

姓名(A):

用户登录名(U):

@xie.com

用户登录名(Windows 2000 以前版本)(W):

< 上一步(B) 下一步(N) > 取消

然后填该用户的密码以及一些属性，点击下一步即可。如图所示：

新建对象 - 用户

创建于: xie.com/

密码(P):

确认密码(C):

☐ 用户下次登录时须更改密码(M)

☐ 用户不能更改密码(S)

☒ 密码永不过期(W)

☐ 帐户已禁用(O)

< 上一步(B) 下一步(N) > 取消

最后点击完成即可，如图所示：

新建对象 - 用户

创建于: xie.com/

你单击“完成”后，下列对象将被创建:

全名: 张三

用户登录名: zhangsan@xie.com

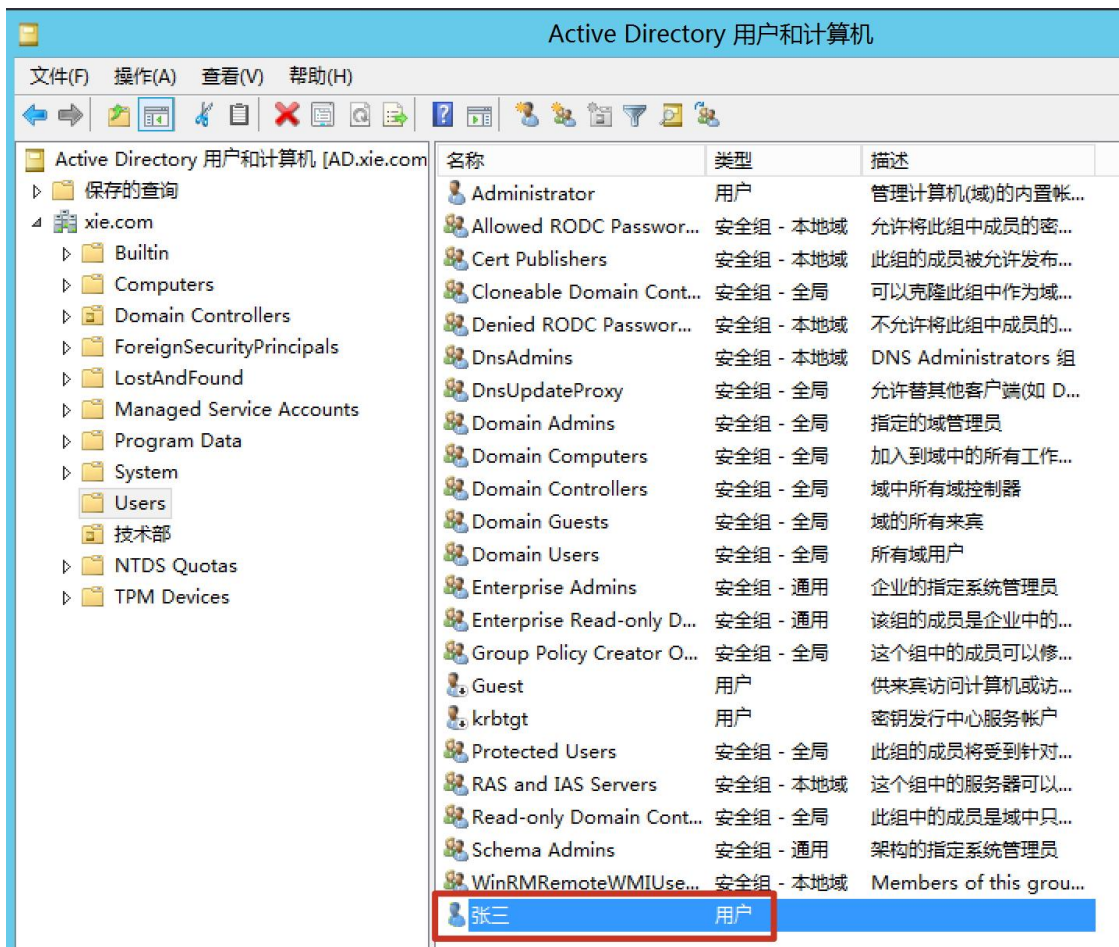
密码永不过期。

< 上一步(B)

完成

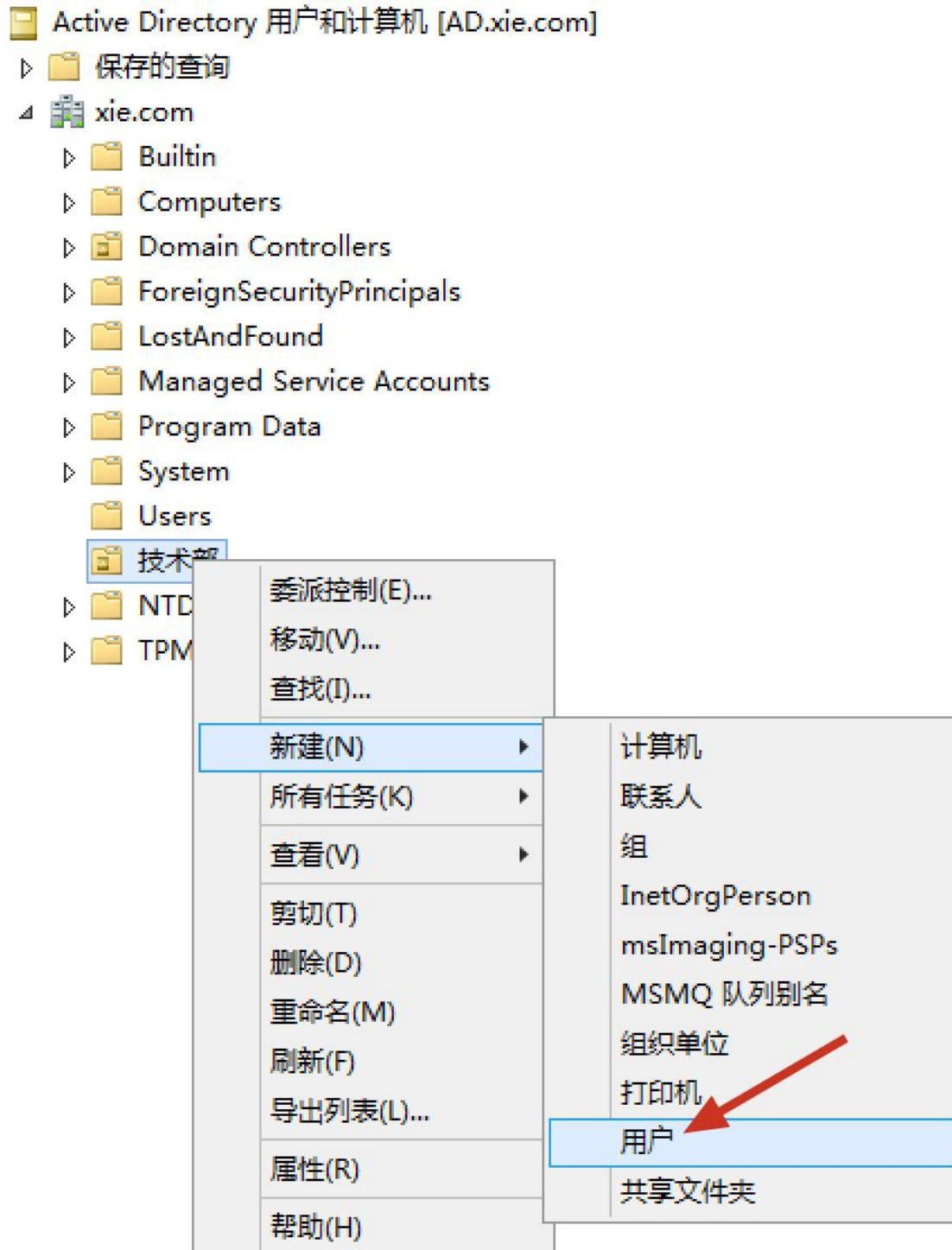
取消

即可在 Users 容器下看到张三用户，如图所示：



也可以新建一个 OU 组织单位，然后在该组织单位下新建用户，这样便于管理不同部门的用户。

如图所示，在技术部组织单位下新建用户。



注：不管是在哪个容器、哪个组织单位下新建用户，该用户均是实现 user 类，在域组 Domain Users 下。

(6) 用户帐户的属性

每个域用户在活动目录数据库内对应的是一个条目对象，因此它有属性。我们在图形化新建域用户时，可以看到有很多需要填的地方。

如图所示，我们把所有需要填的信息都填上，新建一个用户张三。

新建对象 - 用户

创建于: xie.com/Users

姓(L): 张

名(F): 三 英文缩写(I): zhangs

姓名(A): 张三

用户登录名(U): zhangsan @xie.com

用户登录名(Windows 2000 以前版本)(W): XIE\ zhangsan

< 上一步(B) 下一步(N) > 取消

然后通过 LDAP 查询张三用户的属性，如图所示：

CN=张三,CN=Users,DC=xie,DC=com,10.211.55.4 [AD.xie.com]

Attribute	Syntax	Count	Value(s)
accountExpires	Integer8	1	0xFFFFFFFFFFFFFFF
badPasswordTime	Integer8	1	0x0
badPwdCount	Integer	1	0
cn	DirectoryString	1	张三
codePage	Integer	1	0
countryCode	Integer	1	0
displayName	DirectoryString	1	张三
distinguishedName	DN	1	CN=张三,CN=Users,DC=xie,DC=com
dsCorePropagationData	GeneralizedTime	1	1601/1/1 7:00:00
givenName	DirectoryString	1	三
initials	DirectoryString	1	zhangs
instanceType	Integer	1	4
lastLogoff	Integer8	1	0x0
lastLogon	Integer8	1	0x0
logonCount	Integer	1	0
name	DirectoryString	1	张三
nTSecurityDescriptor	NTSecurityDescriptor	1	D:AI(OA;RP;4c164200-20c0-11d0-a768-00aa006e0529;RS)(OA;RP;5f202010-79a5-11d0-9020-00c04fc2d4cf;RS)(OA;RP;bc0ac240-79a9-11d0-9020-00c04f...
objectCategory	DN	1	CN=Person,CN=Schema,CN=Configuration,DC=xie,DC=com
objectClass	OID	4	top;person;organizationalPerson;user
objectGUID	OctetString	1	{3A2987C0-EE07-4378-8D76-F94E1DFA7B85}
objectSid	Sid	1	S-1-5-21-1313979556-3624129433-4055459191-1112
primaryGroupID	Integer	1	513
pwdLastSet	Integer8	1	2021/10/18 23:57:20
sAMAccountName	DirectoryString	1	zhangs
sAMAccountType	Integer	1	805306368
sn	DirectoryString	1	张
userAccountControl	Integer	1	66048
userPrincipalName	DirectoryString	1	zhangs@xie.com
uSNCreated	Integer8	1	0x400D
uSNChanged	Integer8	1	0x400D
whenChanged	GeneralizedTime	1	2021/10/18 23:57:20
whenCreated	GeneralizedTime	1	2021/10/18 23:57:20

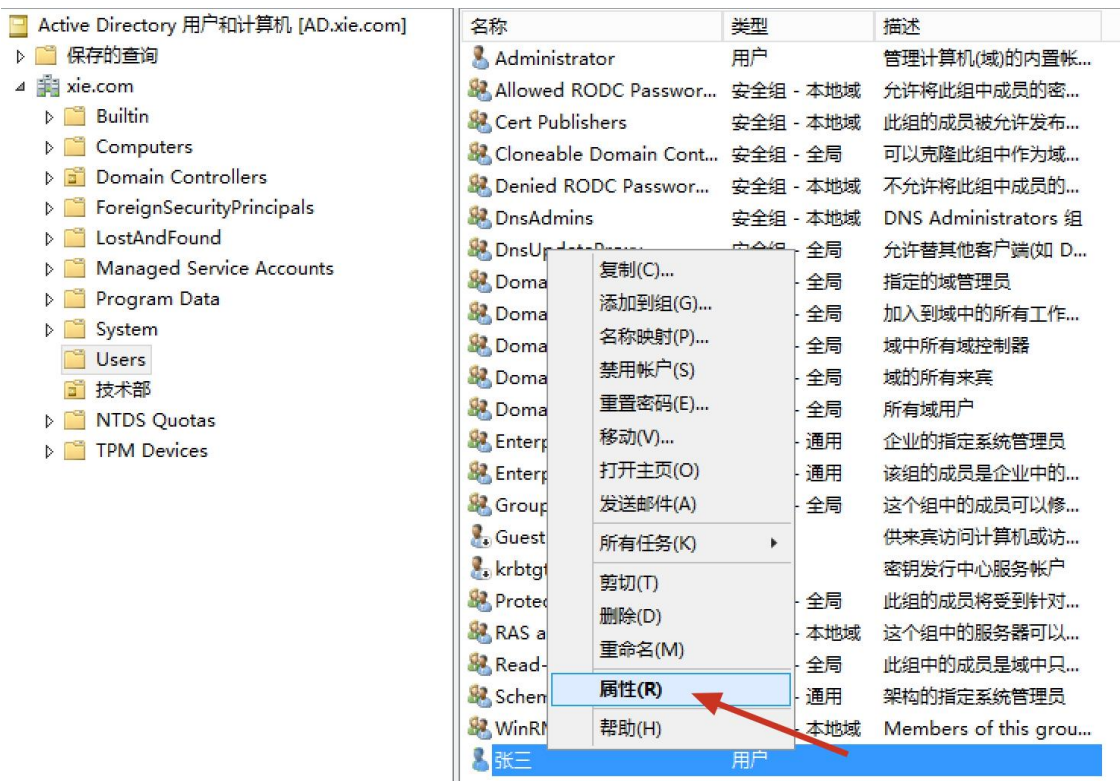
可以看到，图形化界面创建用户时和通过 ldap 查询的一些对应关系，如下所示：

属性	含义
sn	姓
givenName	名
initials	英文
displayName 、 cn 和 name	姓名

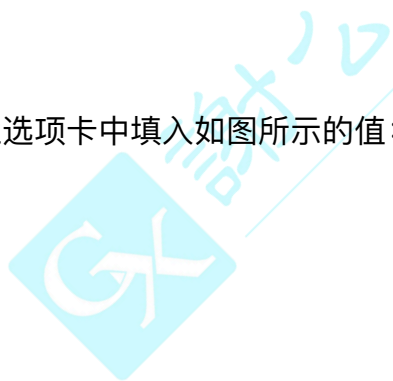
而这里用户登录名就是用来 登录域时所用的登录名。有两种：

- UPN(User Principal Name)：如 zhangs@xie.com 。UPN 的格式与电子邮件账号相同，在整个林内，这个名称必须是唯一的。UPN 并不会随着账户被移动到其他域而改变。
- 用户 SamAccountName：如 xie\zhangs 。这是旧格式的登录账号。Windows2000 之前版本的旧客户端需要使用这种格式来登录域。在以后版本的客户端，也支持使用这种方式登录。在同一个域内，这个名称必须是唯一的。

我们在 Active Directory 用户和计算机中找到该用户，右键属性，查看该用户的更多属性。如图所示：



在地址栏选项卡中填入如图所示的值：



张三 属性

?

x

远程控制		远程桌面服务配置文件		COM+		属性编辑器	
密码复制		拨入	对象	安全	环境	会话	
常规	地址	帐户	配置文件	电话	组织	发布的证书	隶属于

国家/地区(O):

中国

邮政编码(Z):

000001

省/自治区(V):

北京市

市/县(C):

朝阳区

街道(S):

国贸街道

邮政信箱(B):

001122

确定

取消

应用(A)

帮助

在电话选项卡中填入如图所示的值：



张三 属性

?

×

远程控制		远程桌面服务配置文件		COM+		属性编辑器	
密码复制		拨入	对象	安全	环境	会话	
常规	地址	帐户	配置文件	电话	组织	发布的证书	隶属于

电话号码

家庭电话(M):

1111111

其他(O)...

寻呼机(P):

2222222

其他(T)...

移动电话(B):

12345678901

其他(H)...

传真(F):

3333333

其他(E)...

IP 电话(I):

4444444

其他(R)...

注释(N):

^

↓

确定

取消

应用(A)

帮助

再次通过 LDAP 查询张三用户的属性，可以看到，地址和电话选项卡填的值和一些属性的对应关系，如下所示：

属性	含义
co	国家/地址
postalCode	邮政编码
st	省/自治区
l	市/县
streetAddress	街道
postOfficeBox	邮政信箱
homePhone	家庭电话
pager	寻呼机
mobile	移动电话
facsimileTelephoneNumber	传真
ipPhone	ip 电话

我们再次通过 LDAP 查询张三用户的属性，如图所示：



Attribute	Syntax	Count	Value(s)
accountExpires	Integer8	1	0x7FFFFFFF
badPasswordTime	Integer8	1	0x0
badPwdCount	Integer	1	0
c	DirectoryString	1	CN
cn	DirectoryString	1	张三
co	DirectoryString	1	中国
codePage	Integer	1	0
countryCode	Integer	1	156
displayName	DirectoryString	1	张三
distinguishedName	DN	1	CN=张三,CN=Users,DC=xie,DC=com
dsCorePropagationData	GeneralizedTime	1	1601/1/1 7:00:00
facsimileTelephoneNumber	DirectoryString	1	3333333
givenName	DirectoryString	1	三
homePhone	DirectoryString	1	1111111
initials	DirectoryString	1	zhangs
instanceType	Integer	1	4
ipPhone	DirectoryString	1	4444444
l	DirectoryString	1	朝阳区
lastLogoff	Integer8	1	0x0
lastLogon	Integer8	1	0x0
logonCount	Integer	1	0
mobile	DirectoryString	1	12345678901
name	DirectoryString	1	张三
nTSecurityDescriptor	NTSecurityDescriptor	1	D:AI(OA;RP;4c164200-20c0-11d0-a768-00aa006e0529;RS)(OA;RP;5f202010-79a5-11d0-9020-00c04fc2d4cf;RS)(OA;RP;bc0ac240-79a9-11d0-9020-00c04fc2d4cf;RS)
objectCategory	DN	1	CN=Person,CN=Schema,CN=Configuration,DC=xie,DC=com
objectClass	OID	4	top;person;organizationalPerson;user
objectGUID	OctetString	1	{3A29B7C0-EE07-4378-8D76-F94E1DFA78B5}
objectSid	Sid	1	S-1-5-21-1313979556-3624129433-4055459191-1112
pager	DirectoryString	1	2222222
postalCode	DirectoryString	1	000001
postOfficeBox	DirectoryString	1	001122
primaryGroupID	Integer	1	513
pwdLastSet	Integer8	1	2021/10/18 23:57:20
sAMAccountName	DirectoryString	1	zhangsan
sAMAccountType	Integer	1	805306368
sn	DirectoryString	1	张
st	DirectoryString	1	北京市
streetAddress	DirectoryString	1	国贸街道
userAccountControl	Integer	1	66048
userPrincipalName	DirectoryString	1	zhangsan@xie.com
uSNChanged	Integer8	1	0x40E2

用户还有一些其他属性和含义如下：

属性	含义
badPasswordTime	登录时密码错误的时间
badPwdCount	密码错误次数
codePage	代码页
countryCode	国家代码
distinguishedName	dn 名
lastLogoff	最后注销时间
lastLogon	最后登录时间
logonCount	登录次数
nTSecurityDescriptor	该账号的 ACL
objectCategory	对象索引目录，值为单个
objectClass	继承的类，可以有多个

objectGUID	对象的 GUID
objectSid	对象的 SID
primaryGroupID	私密的组 ID
pwdLastSet	密码最后设置的时间
samAccountType	域内机器账号类型
userAccountControl	用户账户控制 ACL
uSNChanged	USN 改变的时间
uSNCreated	USN 创建的时间
whenChanged	账号改变的时间
whenCreated	账号创建的时间

(7) 用户帐户的选项

每个活动目录用户帐户都有许多帐户选项。如下表描述了可用于配置用户帐户的密码设置和安全特定信息的选项。

选项	描述
User must change password at next logon	强制用户在下次登录到网络时更改其密码。
User cannot change password	防止用户更改其密码。
Password never expires	防止用户密码过期。建议服务帐户启用此选项并使用强密码。
Store passwords using reversible encryption	为使用协议以了解用户密码的明文形式的应用程序提供支持。当在因特网认证服务(IAS)中使用挑战-响应认证协议(CHAP)，以及在因特网信息服务(IIS)中使用摘要身份验证时，都需要此选项。
Account is disabled	禁止用户使用所选帐户登录。

Smart card is required for interactive logon	要求用户拥有一张智能卡，以便以交互式的方式登录到网络。用户还必须在计算机上安装一个智能卡读卡器和该智能卡的有效个人识别号(PIN)。
Account is trusted for delegation	该帐户配置了委派属性。
Account is sensitive and cannot be delegated	允许控制用户帐户，例如客户帐户或临时帐户。如果此帐户不能由其他帐户分配给委派，则可以使用此选项。
Use DES encryption types for this account	为数据加密标准(DES)提供支持。DES 支持多级加密，包括微软点对点加密(MPPE)标准（40 位和 56 位）、MPPEStrong（128 位）、互联网协议安全(IPSec)DES（40 位）、IPSec56 位 DES 和 IPSec 三重 DES(3DES)。
Do not require Kerberos preauthentication	不要 Kerberos 预认证。

(8) 查询域用户

在有些场景下，我们需要查询域内的所有域用户；有时候，需要精确查找域内的某个用户。当需求不同时，如何不同的查询域用户呢？

查询域内所有用户

当我们想查询域内的所有用户时，如何将域内所有用户查询出来呢？

系统自带命令

我们可以利用系统自带的 net 命令查询域内所有用户。由于域内的用户都在“domain users”组内，因此可以使用如下命令进行查询。

#查询域内所有用户

```
net group "domain users" /domain
```

#这条命令查询的话，除了会查询出域内所有用户外，还会查询出域控的本地账号 guest

net user /domain

如图所示，使用 net 命令查询域内所有用户。

```
C:\Users\Administrator\Desktop>net user /domain

User accounts for \\DC

-----
Administrator      Guest              hack
krbtgt              test
The command completed successfully.

C:\Users\Administrator\Desktop>net group "domain users" /domain
Group name      Domain Users
Comment         所有域用户

Members

-----
Administrator      hack              krbtgt
test
The command completed successfully.
```

powershell 脚本

也可以利用 PowerSploit 下的 PowerView.ps1 脚本，该脚本的输出用户名比较直观。该脚本的使用如下：

```
Import-Module .\PowerView.ps1
```

```
Get-NetUser | select name
```

如图所示，使用 PowerView.ps1 脚本查询域内所有用户。

```

PS C:\Users\Administrator\Desktop> Import-Module .\PowerView.ps1
PS C:\Users\Administrator\Desktop> Get-NetUser | select name

name
----
Administrator
Guest
krbtgt
hack
test

```

impacket 脚本

在 impacket 里面有一个 samrdump.py 脚本，其通过调用 SAMR 协议去查询域内所有用户。使用命令如下：

```
python3 samrdump.py xie/hack:P@ss1234@10.211.55.4 -csv
```

如图所示，使用 samrdump.py 脚本查询域内所有用户。

```

+ examples git:(master) * python3 samrdump.py xie/hack:P@ss1234@10.211.55.4 -csv
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Retrieving endpoint list from 10.211.55.4
Found domain(s):
. XIE
. Builtin
[*] Looking up users in domain XIE
Found user: Administrator, uid = 500
Found user: Guest, uid = 501
Found user: krbtgt, uid = 502
Found user: hack, uid = 1105
Found user: test, uid = 1107
#Name,RID,FullName,PrimaryGroupId,BadPasswordCount,LogonCount>PasswordLastSet>PasswordDoesNotExpire,AccountIsDisabled,UserComment,ScriptPath
Administrator,500,,513,0,20,2021-10-16 11:29:51.510296,False,False,,
Guest,501,,514,0,0,<never>,True,True,,
krbtgt,502,,513,0,0,2021-10-16 11:26:55.290808,False,True,,
hack,1105,,513,0,11,2021-11-10 16:22:31.470152,False,False,,
test,1107,,513,0,0,2021-10-26 22:12:45.776287,False,False,,
[*] Received 5 entries.

```

adfind 工具

adfind 工具通过 LDAP 协议查询出域内所有用户，由于域用户的 objectCategory 属性为 person 而 objectClass 属性为 user，因此 adfind 查询域内所有用户命令如下：

```
adfind.exe -f "(&(objectCategory=person)(objectClass=user))" -dn
```

如图所示，使用 adfind 工具查询域内所有用户。

```
C:\Users\Administrator\Desktop>adfind.exe -f "(&(objectCategory=person)(objectClass=user))" -dn
AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021

Using server: DC.xie.com:389
Directory: Windows Server 2012 R2
Base DN: DC=xie,DC=com

dn:CN=Administrator,CN=Users,DC=xie,DC=com
dn:CN=Guest,CN=Users,DC=xie,DC=com
dn:CN=krbtgt,CN=Users,DC=xie,DC=com
dn:CN=hack,CN=Users,DC=xie,DC=com
dn:CN=test,CN=Users,DC=xie,DC=com

5 Objects returned
```

精确查询指定用户

有时候，需要精确查询指定用户的详细信息，我们可以用如下方法：

系统自带命令

我们可以利用系统自带的 net 命令查询域内指定用户信息，该命令是通过 SAMR 协议进行查询，如下：

```
net user hack /domain
```

如图所示，使用 net 命令查询 hack 用户信息。

```
C:\Users\Administrator\Desktop>net user hack /domain
User name                hack
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active           Yes
Account expires          Never

Password last set        2021/11/10 16:22:31
Password expires         2024/8/5 16:22:31
Password changeable      2021/11/11 16:22:31
Password required        Yes
User may change password Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               2021/10/26 22:12:25

Logon hours allowed      All

Local Group Memberships
Global Group memberships *Domain Users
The command completed successfully.
```

powershell 脚本

可以利用 PowerSploit 下的 PowerView.ps1 脚本查询域内指定用户详细信息。
该脚本的使用如下：

```
Import-Module .\PowerView.ps1
Get-NetUser hack
```

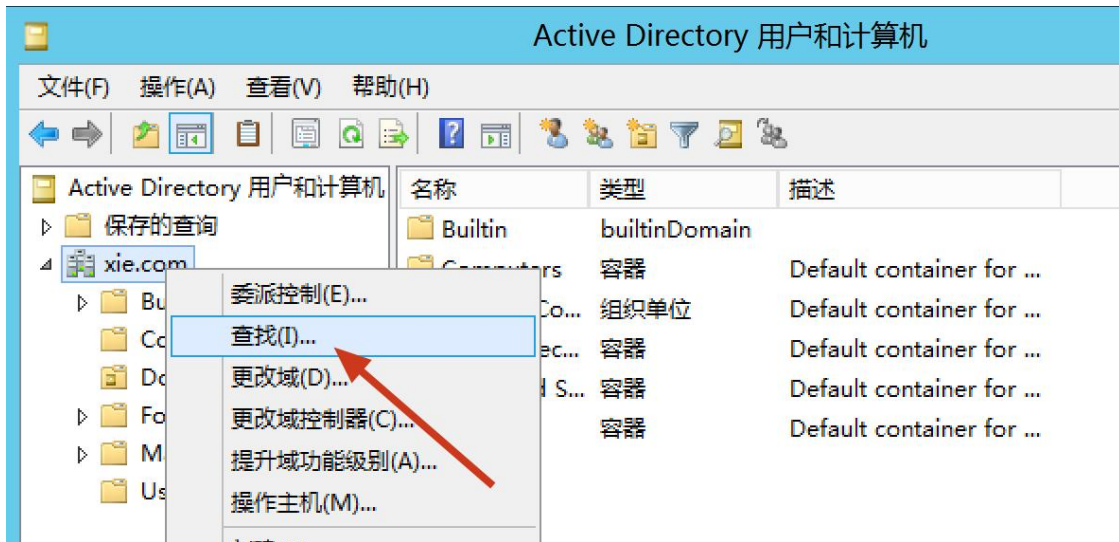
如图所示，使用 PowerView.ps1 脚本查询指定 hack 用户信息。


```
PS C:\Users\Administrator\Desktop> Import-Module .\PowerView.ps1
PS C:\Users\Administrator\Desktop> Get-NetUser hack

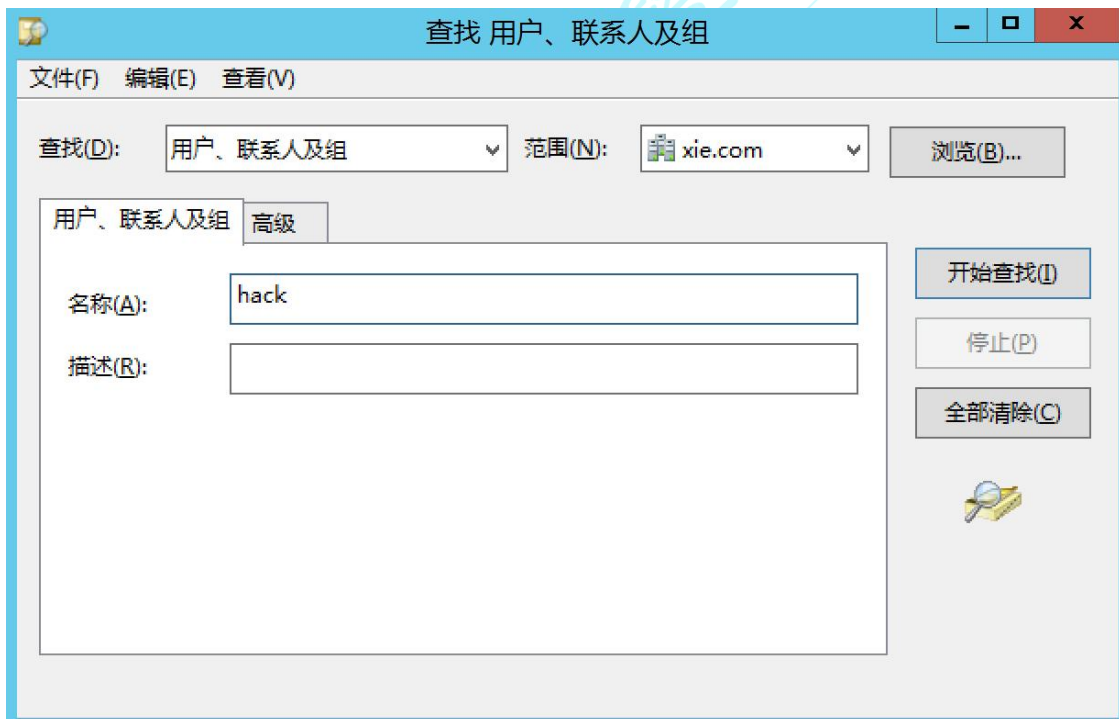
logoncount           : 11
badpasswordtime      : 1601/1/1 8:00:00
distinguishedname    : CN=hack,CN=Users,DC=xie,DC=com
objectclass          : {top, person, organizationalPerson, user}
lastlogontimestamp   : 2021/11/10 17:08:24
userprincipalname    : hack@xie.com
name                 : hack
objectsid            : S-1-5-21-1313979556-3624129433-4055459191-1105
samaccountname       : hack
logonhours           : {255, 255, 255, 255...}
codepage             : 0
samaccounttype       : 805306368
whenchanged          : 2021/11/10 9:08:24
accountexpires       : 0
countrycode          : 0
adspath              : LDAP://CN=hack,CN=Users,DC=xie,DC=com
instancetype         : 4
usncreated           : 12773
objectguid           : 908a4f43-e2c4-4994-8728-b1c42507d357
lastlogoff           : 1601/1/1 8:00:00
objectcategory       : CN=Person,CN=Schema,CN=Configuration,DC=xie,DC=com
dscorepropagationdata : 1601/1/1 0:00:00
lastlogon            : 2021/10/26 22:12:25
badpwdcount          : 0
cn                   : hack
useraccountcontrol   : 512
whencreated          : 2021/10/16 3:37:28
primarygroupid       : 513
pwdlastset           : 2021/11/10 16:22:31
usnchanged           : 20594
```

图形化

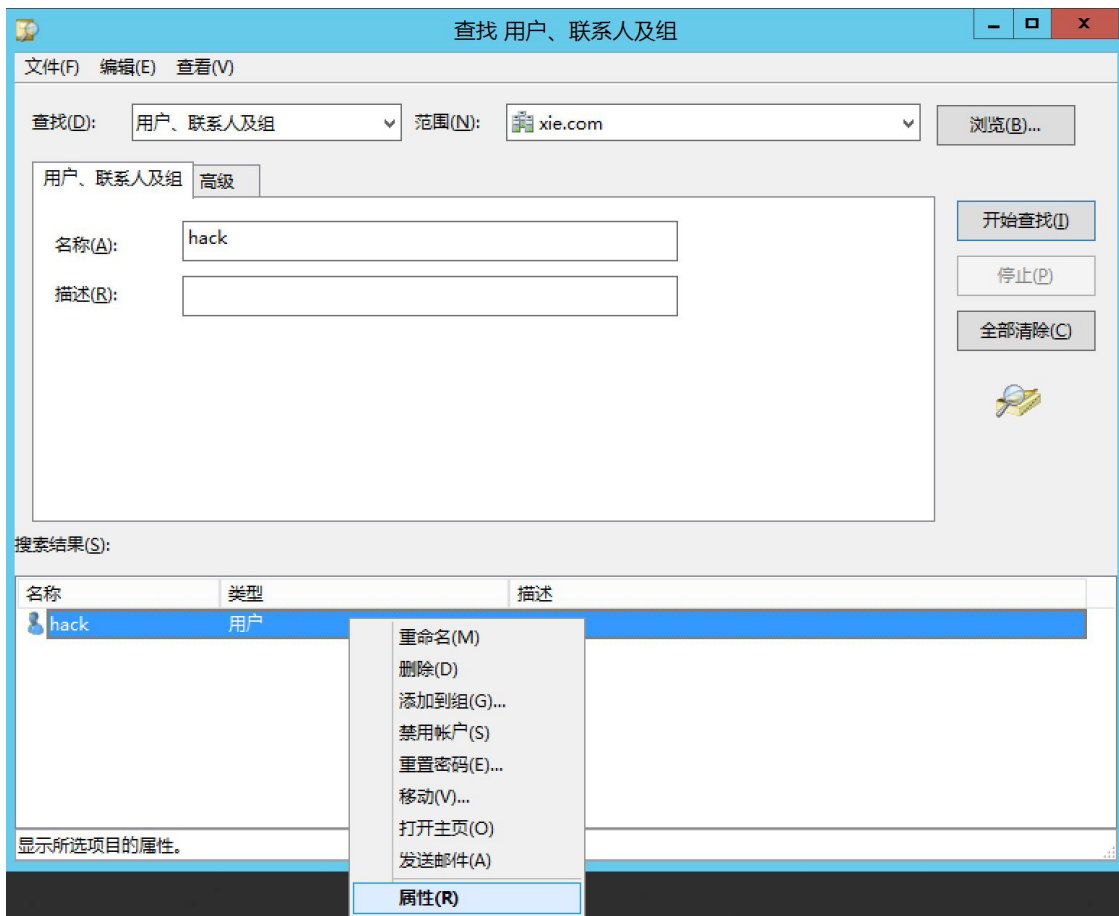
该查询需要在域控上进行。如图所示，打开“Active Directory 用户和计算机”，找到域名，右键——>查找。



如图所示，名称这里点击要搜索的用户名，然后点击“开始查找”。



即可找到该用户。如图所示，右键——>属性，查询指定用户的属性。



即可看到该用户的详细信息，如图所示：

hack 属性

拨入	环境	会话	远程控制	远程桌面服务配置文件	COM+
常规	地址	帐户	配置文件	电话	组织
			密码复制		

用户登录名(U):
 @xie.com

用户登录名(Windows 2000 以前版本)(W):

☐ 解锁帐户(N)

帐户选项(O):

☐ 用户下次登录时须更改密码
☐ 用户不能更改密码
☐ 密码永不过期
☐ 使用可逆加密存储密码

帐户过期

☒ 永不过期(V)
☐ 在这之后(E):

adfind 工具

可以利用 adfind 工具查询域内指定用户详细信息，查询命令如下：

#查询 hack 用户指定信息

adfind.exe -sc u:hack

如图所示，使用 adfind 工具查询指定 hack 用户信息。

```
C:\Users\Administrator\Desktop>AdFind.exe -sc u:hack

AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021

Using server: DC.xie.com:3268
Directory: Windows Server 2012 R2

dn:CN=hack,CN=Users,DC=xie,DC=com
>objectClass: top
>objectClass: person
>objectClass: organizationalPerson
>objectClass: user
>cn: hack
>distinguishedName: CN=hack,CN=Users,DC=xie,DC=com
>instanceType: 4
>whenCreated: 20211016033728.0Z
>whenChanged: 20211110090824.0Z
>uSNCreated: 12773
>uSNChanged: 20594
>name: hack
>objectGUID: {908A4F43-E2C4-4994-8728-B1C42507D357}
>userAccountControl: 512
>primaryGroupID: 513
>objectSid: S-1-5-21-1313979556-3624129433-4055459191-1105
>sAMAccountName: hack
>sAMAccountType: 805306368
>userPrincipalName: hack@xie.com
>objectCategory: CN=Person,CN=Schema,CN=Configuration,DC=xie,DC=com
>dSCorePropagationData: 16010101000000.0Z
>lastLogonTimestamp: 132810089042507565

1 Objects returned
```

2. 服务帐户 Service Accounts

活动目录服务帐户其实就是一种特殊的用户帐户。服务帐户是显式创建的用户帐户，旨在为在 Windows 服务器操作系统上运行的服务提供安全上下文。安全上下文决定了服务访问本地资源和网络资源的能力。Windows 操作系统依赖于服务来运行各种特性。这些服务可以通过应用程序、服务管理单元或任务管理器，或使用 Windows PowerShell 进行配置。

在 2.8 章 SPN 服务主体名称中我们讲了 Kerberos 身份验证使用 SPN 来将服务实例和服务登录帐户相关联。因此，在域中所有的服务都有 SPN，并且所有的服务都有服务帐户。Kerberoasting 攻击就是针对域内服务帐户进行的攻击，详情可以看 4.4 章 Kerberoasting 攻击。

默认情况下，域中每个机器都提供服务，因此默认情况下域中每个机器都有 SPN，并且其服务帐户就是其机器帐户。

如图所示，查询域内机器 win10 注册的 SPN，可以看到默认情况下它注册了 6 个 SPN。

```
PS C:\Users\Administrator> setspn -L Win10
Registered ServicePrincipalNames for CN=WIN10,CN=Computers,DC=xie,DC=com:
    WSMAN/win10
    WSMAN/win10.xie.com
    RestrictedKrbHost/WIN10
    HOST/WIN10
    RestrictedKrbHost/win10.xie.com
    HOST/win10.xie.com
```

再比如 krbtgt 是用户帐户，同时它也是密钥发行中心服务帐户，其在域内提供密钥分发相关的服务，其在域内注册的 SPN 是 kadmin/changepw。

如图所示，可以看到 krbtgt 用户在域内注册的 SPN。

```
CN=krbtgt,CN=Users,DC=xie,DC=com
    kadmin/changepw
```


因此，其实用户帐户可以是服务帐户，机器帐户也可以是服务帐户。它们是否属于服务帐户取决于该帐户是否在域内注册了 SPN。

(1) 新建服务帐户

从上面我们可以得知，只要在域内给用户帐户或机器帐户注册一个 SPN，其帐户就可以成为服务帐户了。而在 2.8 章 SPN 服务主体名称中我们讲到了，如果要给用户帐户注册 SPN 的话需要管理员权限。而给机器帐户注册 SPN 的话，除了域管理员，机器帐户自身也可以，但是其 SPN 只能注册在当前主机下面。

下面我们演示通过域管理员 administrator 将一个普通用户帐户注册成为服务帐户。

实验环境如下：

- 域管理员：administrator
- 普通用户：hack

通过如下命令给 hack 用户注册 test/test SPN。

#查询 hack 用户注册的 SPN

```
setspn -L hack
```

#给 hack 用户注册 test/test SPN

```
setspn -S test/test hack
```

如图所示，给 hack 用户注册 test/test SPN。


```
PS C:\Users\Administrator> setspn -L hack
Registered ServicePrincipalNames for CN=hack,CN=Users,DC=xie,DC=com:
PS C:\Users\Administrator>
PS C:\Users\Administrator> setspn -S test/test hack
Checking domain DC=xie,DC=com 给hack用户注册一个test/test SPN
Registering ServicePrincipalNames for CN=hack,CN=Users,DC=xie,DC=com
test/test
Updated object
PS C:\Users\Administrator> setspn -L hack
Registered ServicePrincipalNames for CN=hack,CN=Users,DC=xie,DC=com:
test/test
```

此时，hack 用户就是一个服务帐户了，因为它在域内提供了 SPN 为 test/test 的服务。我们通过 GetUserSPNs.py 脚本执行如下命令就能请求服务帐户 hack 下注册的所有 SPN 的服务票据了！

```
python3 GetUserSPNs.py -request -dc-ip 10.211.55.4 xie.com/hack:P@ss1234
```

如图所示，可以看到打印出了 SPN 为 test/test 服务的 ST 服务票据。

```
+ examples git:(master) * python3 GetUserSPNs.py -request -dc-ip 10.211.55.4 xie.com/hack:P@ss1234
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
test/test	hack		2021-07-01 21:25:09.806509	2021-12-13 16:55:23.646016	

```
$krb5tgs$23$*hack$XIE.COM$xie.com/hack*$a89c08bbca7efa3d97288ec615fea034371ca189bed23c45154456abf7e30331a02cc82d67490a5db36cf0f8e93a215e
447a85b278e1450c272000b72a1f94da607102364416d7de2ce3d073affe29624f4d54c33076ee30a059b3ffc32bd3baaf2b526eb433c28397682d5ac15d46bf596e2b1c4
76e24a535c819a4fcea52bb325bba049ecf1fb1e2211bf06642723eb667533d61d3d1d64b233410ebd11a7645bcf9c4c46cdba83118faa27819ac517b3d62a2d66e3bda
3b2e102c294dcfd19f90cd1c1962420aa7a595a4a2dfa8ba0d4a5da3404ca3dc594772921c13110a5a8bd1c327c681ef8cea809cfe917d4bc55e9318bdc081eb71630315
5658cd6ea05cd6a409b56ee03be9643d372587b843d26e93ee74f1718558b3654143e3e35ca0c27d8b6e2599751adb806060a943aa0fb44a110ccb754d10f0e8ea9642810
5ebdc9f964812027587f140aa8a1d7c1248e4d432457348c3186374f7b57276c170b39f5c0fba4ae7b76e9d590c0f6dd3eaac36f3897cd52e00cae3169d26c4d9dc8ce35f
5af2245945233564113f3f9f406a2f1b75efcf3add52c72dc3b1a42281e83f21b236752948d4163a4bf311c044609267ebe8cb2ecdc1b741c51c339dca1f47c8bf9c76849
b17a8883f7ffff4dee878a8ca6eaa169ba121819bc0778353d54c64c737e96f4be64ab4916cc5b3b23c42c4f693d1a5c3df5480793344fbd62126875351a06ba94dc64e7
a406714d119c27d000b11087f0ab14670503c870fb5a126ed87cbfec8e9aa0ce264b3b7d349916c9bfc7ad1d1d283a0e2cfe01e0339a671da1748c6b57840b82711e86c6
61da7a0daa8b444155d77beb3345ecc5ba56c81b77b5f10cbc6982eb1bb07b78367c92fa03555f4c426e23d0d5924b071eb055c057ca6fcf593c683a42c4b6a0462f3ce94
9df2a35a1efcc288c56b3fd342eabf7fd7a84baaebe7e803965a216f50b96beacda481c89f058327fec1e14909eafc4658a74a3452d7157c3c7da0d0dccc8f63fb03f1127
07f82ab5fe65d78c6d98c4fb6688163d6859baf0f8bfc005035f1577c65496aef876184abb50d1dc6c5b897319bd7f0b0c90bf4dca50d9d0c155ed4dc9bfc2d0787d8b757
cce2cffeceab6b47dc65ffb28911be9bb7c86e35de29acd216bf54f06af859a448b40f0d396c0970d6e6c008e7499eb78388df852f931b1a9b9e8754dc181c877064247d015
45ffe959cd6830dcf0cb5e00c6f6
```

(2) 查询服务帐户

查询域内的服务帐户可以转换为查询域内注册的 SPN。有很多种手段进行查询，且使用普通域用户权限即可查询。

通过 setspn 查询执行如下命令查询域内注册的所有 SPN，即可看到域内所有的服务帐户。

#查看当前域内注册的所有 SPN

setspn -Q */*

如图所示，通过 setspn 查询域内注册的所有 SPN。

```
C:\Users\hack.XIE\Desktop>setspn -Q */*
Checking domain DC=xie,DC=com
CN=AD01,OU=Domain Controllers,DC=xie,DC=com
exchangeAB/AD01
exchangeAB/AD01.xie.com
Dfsr-12F9A27C-BF97-4787-9364-D31B6C55EB04/AD01.xie.com
ldap/AD01.xie.com/ForestDnsZones.xie.com
ldap/AD01.xie.com/DomainDnsZones.xie.com
DNS/AD01.xie.com
GC/AD01.xie.com/xie.com
RestrictedKrbHost/AD01.xie.com
RestrictedKrbHost/AD01
RPC/488c533a-cddd-4cee-869a-c8a4efb7fc9a._msdcs.xie.com
HOST/AD01/XIE
HOST/AD01.xie.com/XIE
HOST/AD01
HOST/AD01.xie.com
HOST/AD01.xie.com/xie.com
E3514235-4B06-11D1-AB04-00C04FC2DCD2/488c533a-cddd-4cee-869a-c8a4efb7fc9a/xie.com
ldap/AD01/XIE
ldap/488c533a-cddd-4cee-869a-c8a4efb7fc9a._msdcs.xie.com
ldap/AD01.xie.com/XIE
ldap/AD01
ldap/AD01.xie.com
ldap/AD01.xie.com/xie.com
CN=krbtgt,CN=Users,DC=xie,DC=com
kadmin/changepw
CN=MAIL,CN=Computers,DC=xie,DC=com
IMAP/MAIL
IMAP/mail.xie.com
IMAP4/MAIL
IMAP4/mail.xie.com
POP/MAIL
POP/mail.xie.com
```

还可以使用 impacket 中的 GetUserSPNs.py 脚本执行如下命令查询服务账号是用户类型的服务，也就是 SPN 是注册在用户帐户下的服务，该脚本的执行只需要提供一个有效的域用户即可。

python3 GetUserSPNs.py -dc-ip 10.211.55.4 xie.com/hack:P@ss1234

如图所示，查询服务帐户是用户类型的服务。

```

→ examples git:(master) * python3 GetUserSPNs.py -dc-ip 10.211.55.4 xie.com/hack:P@ss1234
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

ServicePrincipalName  Name  MemberOf  PasswordLastSet  LastLogon  Delegation
-----
test/test             hack  -----  2021-07-01 21:25:09.806509  2022-01-20 14:46:43.307079

```

3. 机器帐户 Computer Accounts

活动目录机器帐户其实就是一种特殊的用户帐户，只不过其不能用于登录。机器帐户可以代表一个物理实体，如域内机器。在域内，机器用户跟域用户一样，也是域内的成员，它在域内的用户名是机器用户名+\$，比如机器 Win8 的机器用户为：Win8\$，它在本地的用户名是 System。机器用户的密码是系统随机生成的，密码强度是 120 个字符，而且会定时更新。

如图所示，使用 mimikatz 抓取机器用户 Win7\$ 在内存中的凭据，可以看到它的密码是如此的复杂。

```

msv :
[00000003] Primary
* Username : WIN7$
* Domain   : XIE
* NTLM     : c62ad63ed2f04e78ca97efeea85e5878
* SHA1     : cf1144956ef09b0cd46d6b85e15f81ae6689ccfa
tspkg :
wdigest :
* Username : WIN7$
* Domain   : XIE
* Password : ex1kgnQg;hYrwu Nn0_59Bdz<tk<]t;nT:1WPA*N1/\]5fw2S>.j18bG_VHdp#;]wR7Z IH51G/soN2yahw<N1B,<3#@4aJjky8-9CdTe*,?*\&k32 1OHP
kerberos :
* Username : win7$
* Domain   : XIE.COM
* Password : ex1kgnQg;hYrwu Nn0_59Bdz<tk<]t;nT:1WPA*N1/\]5fw2S>.j18bG_VHdp#;]wR7Z IH51G/soN2yahw<N1B,<3#@4aJjky8-9CdTe*,?*\&k32 1OHP
ssp :
credman :

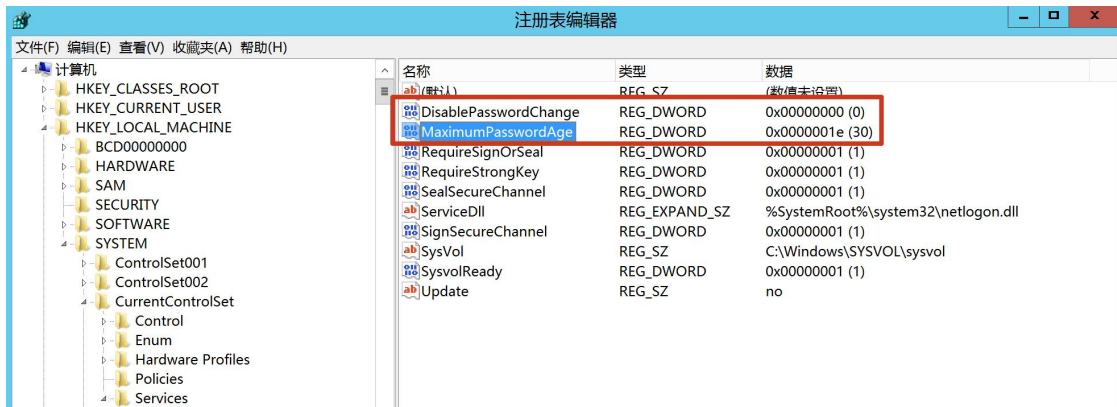
```

可以通过查询以下注册表的相关值来查看机器用户密码是否定时更新以及更新的时间。

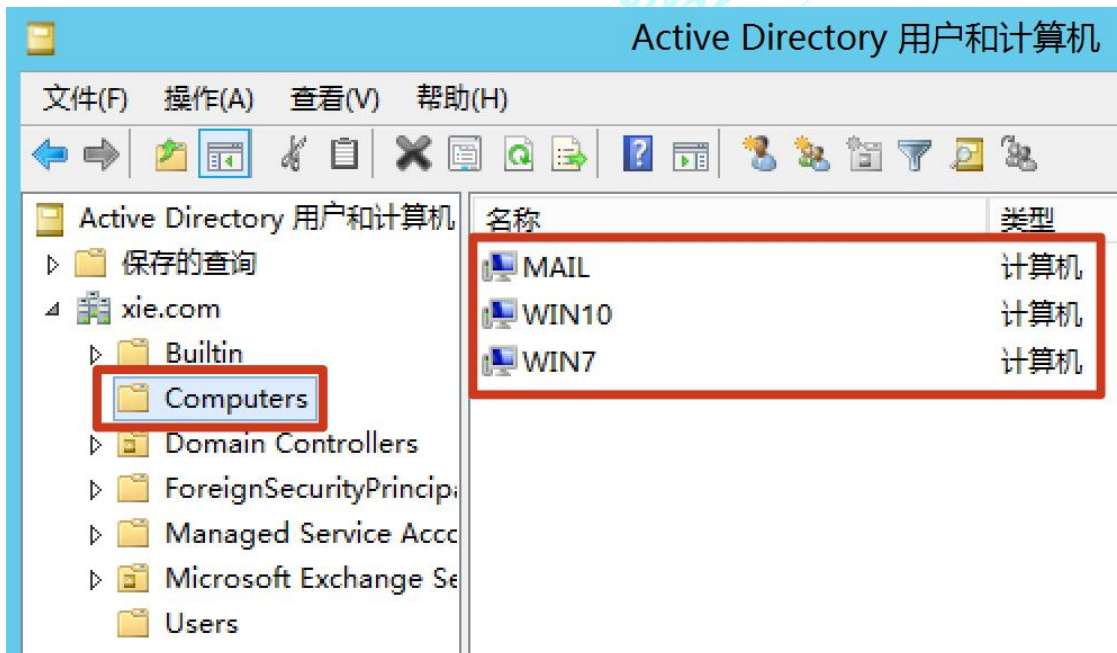
HKLM\SYSTEM\CurrentControlSet\Services\Netlogon\Parameters

DisablePasswordChange 值决定机器用户密码是否定时更新，默认值为 0，值为 0 的话，表示定时更新。MaximumPasswordAge 值决定机器用户密码更新的时间，默认为 30 天。

如图所示，可以看到 DisablePasswordChange 值为 0，MaximumPasswordAge 值为 30。



机器在加入域后，都会存储在 CN=Computers 容器中。如图所示：

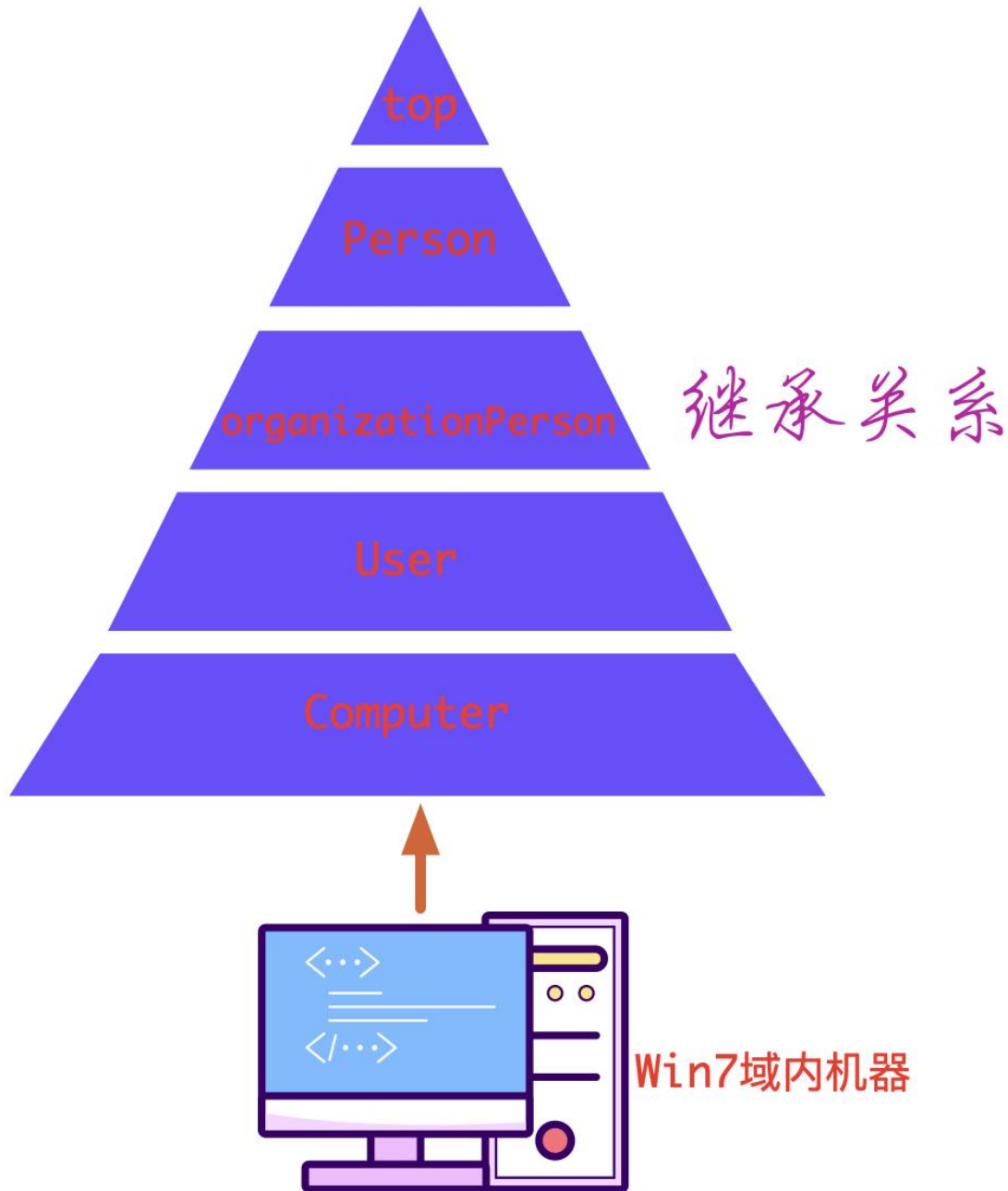


我们以域内机器 Win7 为例，通过查看其 objectClass 属性可以得知，其继承于 computer——>user——>organizationalPerson——>person——>top 类。如图所示：

Attribute	Syntax	Count	Value(s)
accountExpires	Integer8	1	0x7FFFFFFFFFFFFFFF
badPasswordTime	Integer8	1	0x0
badPwdCount	Integer	1	0
cn	DirectoryString	1	WIN7
codePage	Integer	1	0
countryCode	Integer	1	0
distinguishedName	DN	1	CN=WIN7,CN=Computers,DC=xie,DC=com
dnsHostName	DirectoryString	1	WIN7.xie.com
dSCorePropagationData	GeneralizedTime	3	2021/3/7 17:28:31;2021/3/7 17:28:31;1601/1/1 7:04:17
instanceType	Integer	1	4
isCriticalSystemObject	Boolean	1	FALSE
lastLogoff	Integer8	1	0x0
lastLogon	Integer8	1	2021/2/27 21:08:40
lastLogonTimestamp	Integer8	1	2021/2/27 21:07:59
localPolicyFlags	Integer	1	0
logonCount	Integer	1	6
msDS-SupportedEncryp...	Integer	1	28
name	DirectoryString	1	WIN7
nTSecurityDescriptor	NTSecurityDescriptor	1	D:AI(OA;WP;5f202010-79a5-11d0-9020-00c04fc2d4cf;bf967a86-0de6-11d0-a285-00aa003049e
objectCategory	DN	1	CN=Computer,CN=Schema,CN=Configuration,DC=xie,DC=com
objectClass	OID	5	top;person;organizationalPerson;user;computer
objectGUID	OctetString	1	{E9D41A8D-2DE6-4797-8A9C-E377FA486E43}
objectSid	Sid	1	S-1-5-21-1313979556-3624129433-4055459191-1105
operatingSystem	DirectoryString	1	Windows 7 专业版
operatingSystemVersion	DirectoryString	1	6.1 (7600)
primaryGroupID	Integer	1	515
pwdLastSet	Integer8	1	2021/2/27 21:07:59
sAMAccountName	DirectoryString	1	WIN7\$
sAMAccountType	Integer	1	805306369
servicePrincipalName	DirectoryString	4	RestrictedKrbHost/WIN7;HOST/WIN7;RestrictedKrbHost/WIN7.xie.com;HOST/WIN7.xie.com
userAccountControl	Integer	1	4096
uSNChanged	Integer8	1	0x31FA
uSNCreated	Integer8	1	0x31EF
whenChanged	GeneralizedTime	1	2021/2/27 21:08:33
whenCreated	GeneralizedTime	1	2021/2/27 21:07:59

其继承关系如图所示：





Win7 机器是 computer 类的实例，而 computer 类又是 user 类的子类。而域用户是 user 类的实例。子类默认可以继承父类的所有属性，因此域用户该有的属性，机器用户都有。因此在域内，机器用户其实就是一种特殊的用户，只不过其不能正常登录系统。机器用户也叫计算机用户，域内有多少机器，就有多少机器用户，域内每台机器都对应一个机器用户。机器用户在域内的名字，就是 机器名

+\$, 如机器名是 win7 的话, 那么机器用户名就是 win7\$。这个值可以在机器的 samAccountName 属性看到。

如图所示, 可以看到 win7 机器的 samAccountName 属性。

Attribute	Syntax	Count	Value(s)
badPwdCount	Integer	1	107
cn	DirectoryString	1	WIN7
codePage	Integer	1	0
countryCode	Integer	1	0
distinguishedName	DN	1	CN=WIN7,CN=Computers,DC=xie,DC=com
dnsHostName	DirectoryString	1	WIN7.xie.com
dSCorePropagationData	GeneralizedTime	3	2021/3/7 17:28:31;2021/3/7 17:28:31;1601/1/1 7:04:17
instanceType	Integer	1	4
isCriticalSystemObject	Boolean	1	FALSE
lastLogoff	Integer8	1	0x0
lastLogon	Integer8	1	2021/11/11 10:26:52
lastLogonTimestamp	Integer8	1	2021/11/11 10:25:27
localPolicyFlags	Integer	1	0
logonCount	Integer	1	6
msDS-SupportedEncryp...	Integer	1	28
name	DirectoryString	1	WIN7
nTSecurityDescriptor	NTSecurityDescriptor	1	D:AI(OA;;WP;5f202010-79a5-11d0-9020-00c04fc2d4cf;bf967a86-0de6-11d0-a285-00aa003049
objectCategory	DN	1	CN=Computer,CN=Schema,CN=Configuration,DC=xie,DC=com
objectClass	OID	5	top;person;organizationalPerson;user;computer
objectGUID	OctetString	1	{E9D41A8D-2DE8-4797-8A9C-E5FFFA46BE43}
objectSid	Sid	1	S-1-5-21-1313979556-3624129433-4055459191-1105
operatingSystem	DirectoryString	1	Windows 7 专业版
operatingSystemVersion	DirectoryString	1	6.1 (7600)
primaryGroupID	Integer	1	515
pwdLastSet	Integer8	1	2021/2/27 21:07:59
sAMAccountName	DirectoryString	1	WIN7\$
sAMAccountType	Integer	1	805306369
servicePrincipalName	DirectoryString	4	RestrictedKrbHost/WIN7;HOST/WIN7;RestrictedKrbHost/WIN7.xie.com;HOST/WIN7.xie.com
userAccountControl	Integer	1	4096
uSNCreated	Integer8	1	0x0250
uSNCreated	Integer8	1	0x31EF
whenChanged	GeneralizedTime	1	2021/11/11 10:25:27
whenCreated	GeneralizedTime	1	2021/2/27 21:07:59

机器在加入域后, 会将机器帐户的密码同步到域控制器并保存在域控制器的 NTDS.dit 活动目录数据库文件中。机器帐户的密码默认每 30 天自动更新, 密码长度为 120 个字符, 所以即使我们获得了机器帐户密码的哈希值, 也几乎无法还原出机器帐户的明文口令。

如图所示, 导出 win7 机器的机器帐户哈希。


```
+ examples git:(master) * python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.4 -just-dc-user "Win7$"  
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation  
  
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)  
[*] Using the DRSUAPI method to get NTDS.DIT secrets  
WIN7$:1105:aad3b435b51404eeaad3b435b51404ee:063e884fda637cdc737ee47da7a82442:::  
[*] Kerberos keys grabbed  
WIN7$:aes256-cts-hmac-sha1-96:b6fc51b50413b1bf1b0d301da3f0a444b85f0089ab880e95c23260e3b9bed2a8  
WIN7$:aes128-cts-hmac-sha1-96:01d0a21c4b576f71481b4546026fb1a6  
WIN7$:des-cbc-md5:07aeb571594bcbcb  
[*] Cleaning up...
```

拿 win7 机器的机器帐户哈希去在线网站破解，如图所示，可以看到破解不出来。

密文: 063e884fda637cdc737ee47da7a82442

类型: 自动 [帮助]

查询 加密

查询结果:
未查到
已加入本站后台解密，请等待最多5天，如果解密成功将自动给你发送邮件通知，否则表示解密失败
询已经非常强大，实时查询未查到则后台解密成功的希望并不大
[\[不知道密文类型?\]](#)

(1) 新建机器用户

默认情况下，经过身份验证的域内用户可以创建最多十个机器账户，这个数量是由域的 ms-DS-MachineAccountQuota 属性决定。

如图所示，查看域的 ms-DS-MachineAccountQuota 属性，默认为 10。



官方参考: <https://support.microsoft.com/en-us/help/243327/default-limit-to-number-of-workstations-a-user-can-join-to-the-domain>

可以通过 python 脚本利用 SAMR 协议远程创建机器用户, 也可以利用 powershell 脚本创建机器用户, 如下:

python 脚本创建

使用 addcomputer.py 脚本执行如下命令利用 SAMR 协议远程新建一个域内机器用户 machine, 密码为 root。

```
python3 addcomputer.py -computer-name 'machine' -computer-pass 'root' -dc-ip 10.211.55.4 'xie.com/hack:P@ss1234' -method SAMR -debug
```

如图所示, 使用 addcomputer.py 脚本创建机器用户 machine。

```
➔ examples git:(master) * python3 addcomputer.py -computer-name 'machine' -computer-pass 'root' -dc-ip 10.211.55.4 'xie.com/hack:P@ss1234' -method SAMR -debug
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[+] Impacket Library Installation Path: /Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-package
s/impacket-0.9.24.dev1-py3.8.egg/impacket
[*] Opening domain XIE...
[*] Successfully added machine account machine$ with password root.
```

通过这种方式创建的机器用户没有 SPN，如图所示，查询 machine 机器的 SPN，可以看到其没有 SPN。

```
PS C:\Users\hack.XIE\Desktop> setspn -L machine
Registered ServicePrincipalNames for CN=machine,CN=Computers,DC=xie,DC=com:
PS C:\Users\hack.XIE\Desktop>
```

powershell 脚本创建

使用 powershell 脚本执行如下命令在域内机器上创建一个机器用户 machine2，密码为 root。

```
Import-Module .\New-MachineAccount.ps1
New-MachineAccount -MachineAccount machine2 -Password root
```

如图所示，通过 powershell 脚本创建机器用户 machine2。

```
PS C:\Users\hack.XIE\Desktop> Import-Module .\New-MachineAccount.ps1
PS C:\Users\hack.XIE\Desktop> New-MachineAccount -MachineAccount machine2 -Password root
[+] New Machine account is Success! Account: machine2$, Password: root
```

通过这种方式创建的机器用户会有 SPN。

如图所示，查询 machine2 机器的 SPN，可以看到有 SPN。

```
PS C:\Users\hack.XIE\Desktop> setspn -L machine2
Registered ServicePrincipalNames for CN=machine2,CN=Computers,DC=xie,DC=com:
    RestrictedKrbHost/machine2
    HOST/machine2
    RestrictedKrbHost/machine2.xie.com
    HOST/machine2.xie.com
```

不管通过什么方式创建机器用户，被创建的机器用户的 mS-DS-CreatorSID 属性的值是创建用户的 SID。

如图所示，查询 machine 机器用户的 mS-DS-CreatorSID 属性。

machine 属性

常规

操作系统

隶属于

委派

密码复制

位置

管理者

对象

安全

拨入

属性编辑器

组或用户名(G):

Organization Management (XIE\Organization Management)

Delegated Setup (XIE\Delegated Setup)

Exchange Servers (XIE\Exchange Servers)

Exchange Trusted Subsystem (XIE\Exchange Trusted Subsystem)

Exchange Windows Permissions (XIE\Exchange Windows Permis...

hack

Domain Admins (XIE\Domain Admins)

Cert Publishers (XIE\Cert Publishers)

添加(D)...

删除(R)

hack 的权限(P)

	允许	拒绝
Validated write to MS_DS Additional DNS Hos...	☐	☐
更改密码	☒	☐
另外发送为	☒	☐
另外接收为	☒	☐
已验证的到 DNS 主机名的写入	☒	☐
已验证的到服务主体名称的写入	☒	☐
允许身份验证	☒	☐

有关特殊权限或高级设置，请单击“高级”。

高级(V)

确定

取消

应用(A)

帮助

(2) 查询机器用户

查询域内的机器用户，就是查询域内的机器。在有些场景下，我们需要查询域内的所有机器用户；有时候，需要精确查找域内的某台机器。当需求不同时，如何不同的查询机器用户呢？

查询域内所有机器用户

当我们想查询域内的所有机器用户时，如何将域内所有机器用户查询出来呢？

系统自带命令

我们可以利用系统自带的 net 命令查询域内所有机器用户。由于域内的机器都在“domain computers”组内，因此可以使用如下命令进行查询：

```
net group "domain computers" /domain
```

如图所示，使用 net 命令查询出了域内所有的机器，但是不包括域控。

```
C:\Users\Administrator\Desktop>net group "domain computers" /domain
Group name      Domain Computers
Comment         加入到域中的所有工作站和服务
Members

-----
MAIL$           WIN10$           WIN7$
The command completed successfully.
```

powershell 脚本

也可以利用 PowerSploit 下的 PowerView.ps1 脚本，该脚本会查询出域内的所有机器，包括域控。该脚本的使用如下：

```
Import-Module .\PowerView.ps1;
```

```
#查询域内主机，包括域控
```

```
Get-NetComputer
```

如图所示，使用 PowerView.ps1 脚本查询出了域内所有的机器，包括域控。


```
PS C:\Users\Administrator\Desktop> Import-Module .\PowerView.ps1
PS C:\Users\Administrator\Desktop> Get-NetComputer
AD01.xie.com
WIN7.xie.com
mail.xie.com
win10.xie.com
```

adfind 工具

adfind 工具通过 LDAP 协议查询出域内所有机器用户，由于域内机器用户的 objectCategory 属性和 objectClass 属性均为 Computer，因此 adfind 查询域内所有机器用户命令如下：

```
adfind.exe -f "(&(objectCategory=computer)(objectClass=computer))" -dn
```

如图所示，使用 adfind 工具查询域内所有的机器，包括域控。

```
C:\Users\Administrator\Desktop>adfind.exe -f "(&(objectCategory=computer)(objectClass=computer))" -dn
AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021

Using server: AD01.xie.com:389
Directory: Windows Server 2012 R2
Base DN: DC=xie,DC=com

dn:CN=AD01,OU=Domain Controllers,DC=xie,DC=com
dn:CN=WIN7,CN=Computers,DC=xie,DC=com
dn:CN=MAIL,CN=Computers,DC=xie,DC=com
dn:CN=WIN10,CN=Computers,DC=xie,DC=com

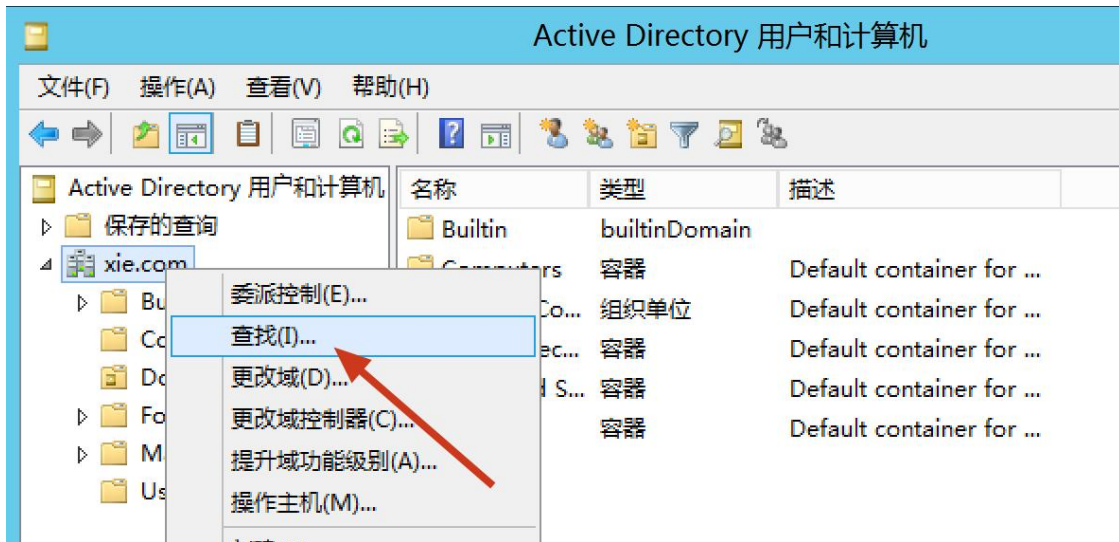
4 Objects returned
```

精确查询指定机器用户

有时候，需要精确查询指定用户的详细信息，我们可以用如下方法：

图形化

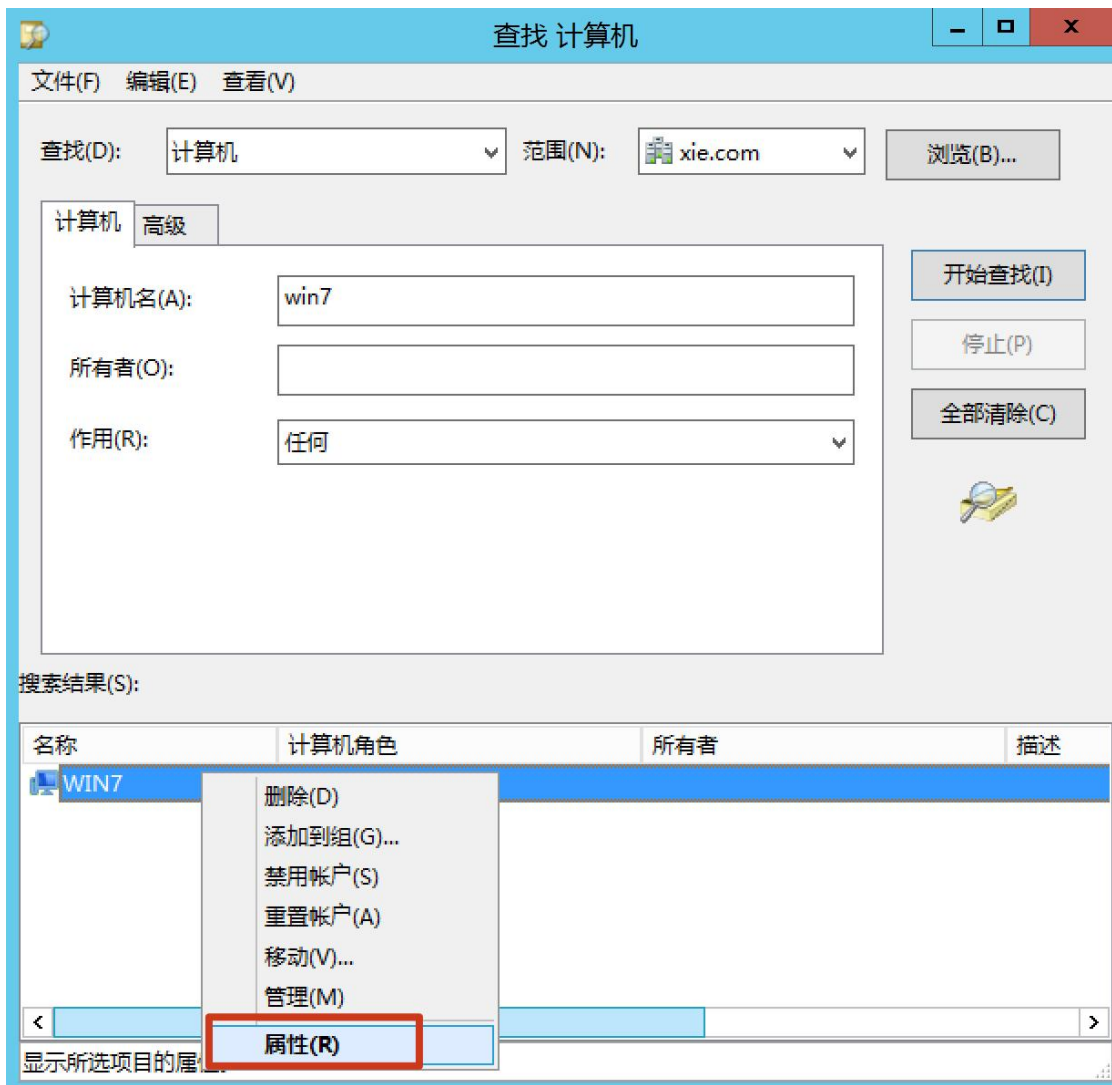
该查询需要在域控上进行。如图所示，打开“Active Directory 用户和计算机”，找到域名，右键——>查找。



查找这里选择计算机”，然后计算机名这里填入要搜索的机器名，然后点击“开始查找”，如图所示：



即可找到该机器用户，如图所示，右键——>属性，查询指定机器的属性。



即可看到该机器用户的详细信息，如图所示：

WIN7 属性

常规

操作系统

隶属于

委派

密码复制

位置

管理者

拨入



WIN7

计算机名(Windows 2000 以前版本)(W):

WIN7

DNS 名称(N):

WIN7.xie.com

DC 类型(T):

工作站或服务器

站点(S):

描述(D):

确定

取消

应用(A)

帮助

adfind 工具

也可以利用 adfind 工具查询域内指定机器用户详细信息，查询命令如下：

#查询指定机器 mail 详细信息

```
AdFind.exe -f "&(objectcategory=computer)(name=mail)"
```

如图所示，使用 adfind 工具查询指定机器 MAIL 的详细信息。

```
C:\Users\Administrator\Desktop>AdFind.exe -f "&(objectcategory=computer)(name=mail)"

AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021

Using server: AD01.xie.com:389
Directory: Windows Server 2012 R2
Base DN: DC=xie,DC=com

dn:CN=MAIL,CN=Computers,DC=xie,DC=com
>objectClass: top
>objectClass: person
>objectClass: organizationalPerson
>objectClass: user
>objectClass: computer
>cn: MAIL
>distinguishedName: CN=MAIL,CN=Computers,DC=xie,DC=com
>instanceType: 4
>whenCreated: 20210307080618.0Z
>whenChanged: 20211111142118.0Z
>uSNCreated: 20499
>memberOf: CN=Exchange Install Domain Servers,CN=Microsoft Exchange System Objects,DC=xie,DC=com
>memberOf: CN=Managed Availability Servers,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
>memberOf: CN=Exchange Trusted Subsystem,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
>memberOf: CN=Exchange Servers,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
>uSNChanged: 53856
>name: MAIL
>objectGUID: {C7013A79-8AE0-4EEC-8DF6-224B90F36AE0}
>userAccountControl: 4096
>badPwdCount: 0
>codePage: 0
>countryCode: 0
>badPasswordTime: 132696194460428923
>lastLogoff: 0
>lastLogon: 132811167676919264
>localPolicyFlags: 0
>pwdLastSet: 132811140783301802
>primaryGroupID: 515
>objectSid: S-1-5-21-1313979556-3624129433-4055459191-1107
>accountExpires: 9223372036854775807
>logonCount: 162
>sAMAccountName: MAIL$
>sAMAccountType: 805306369
>operatingSystem: Windows Server 2012 R2 Standard
>operatingSystemVersion: 6.3 (9600)
>dNSHostName: mail.xie.com
>servicePrincipalName: IMAP/MAIL
>servicePrincipalName: IMAP/mail.xie.com
>servicePrincipalName: IMAP4/MAIL
>servicePrincipalName: IMAP4/mail.xie.com
>servicePrincipalName: POP/MAIL
>servicePrincipalName: POP/mail.xie.com
```

(3) 机器属性解读

通过 ldap 查询域内机器属性及含义如下：

属性	含义
accountExpires	账号过期时间
badPasswordTime	登录时密码错误的时间
badPwdCount	密码错误次数
cn	cn 名
codePage	代码
countryCode	国家代码
distinguishedName	dn 名
dNSHostName	dns 主机名
lastLogon	最后登录时间
logonCount	登录次数
name	名字
nTSecurityDescriptor	该账号的 ACL
objectCategory	对象索引目录，值为单个
objectClass	继承的类，可以有多个
objectGUID	对象的 GUID
objectSid	对象的 SID
operatingSystem	操作系统
operatingSystemServicePack	操作系统服务版本
operatingSystemVersion	操作系统版本
primaryGroupID	私密的组 ID
pwdLastSet	密码最后设置的时间
samAccountName	域内机器账号名
samAccountType	域内机器账号类型
servicePrincipalName	SPN

- 明文密码为: ex1kgnQg;,hYrwu
Nn0_59Bdztk<]t;nT:1WPA^N1/\]5fw2S.ji8bG_VHdp#;]wR7Z
IH51G/soN2yahW<N1B,<3#@4aJjky8-9CdTe,?*&k32 iOHP。

如图所示, mimikatz 抓取 win7\$机器帐户的凭据。

```
msv :
[00000003] Primary
* Username : WIN7$
* Domain   : XIE
* NTLM     : c62ad63ed2f04e78ca97efeea85e5878
* SHA1     : cf1144956ef09b0cd46d6b85e15f81ae6689ccfa
tspkg :
wdigest :
* Username : WIN7$
* Domain   : XIE
* Password : ex1kgnQg;,hYrwu Nn0_59Bdztk<]t;nT:1WPA^N1/\]5fw2S.ji8bG_VHdp#;]wR7Z IH51G/soN2yahW<N1B,<3#@4aJjky8-9CdTe,?*&k32 iOHP
kerberos :
* Username : win7$
* Domain   : XIE.COM
* Password : ex1kgnQg;,hYrwu Nn0_59Bdztk<]t;nT:1WPA^N1/\]5fw2S.ji8bG_VHdp#;]wR7Z IH51G/soN2yahW<N1B,<3#@4aJjky8-9CdTe,?*&k32 iOHP
ssp :
credman :
```

Win7 机器本地 administrator 账号密码为 root, 如图所示:

```
msv :
[00000003] Primary
* Username : Administrator
* Domain   : WIN7
* LM       : d480ea9533c500d4aad3b435b51404ee
* NTLM     : 329153f560eb329c0e1deea55e88a1e9
* SHA1     : a2e138ad319a0e08ffc4a185ce05933bf5c01d5c
tspkg :
* Username : Administrator
* Domain   : WIN7
* Password : root
wdigest :
* Username : Administrator
* Domain   : WIN7
* Password : root
kerberos :
* Username : Administrator
* Domain   : WIN7
* Password : root
ssp :
credman :
```

于是我们可以使用如下几种方式进行域查询。

本地获取 system 权限进行域查询

如图所示，可以看到在本地 administrator 权限下进行域查询提示权限拒绝。

```
C:\Users\Administrator\Desktop>whoami
win7\administrator

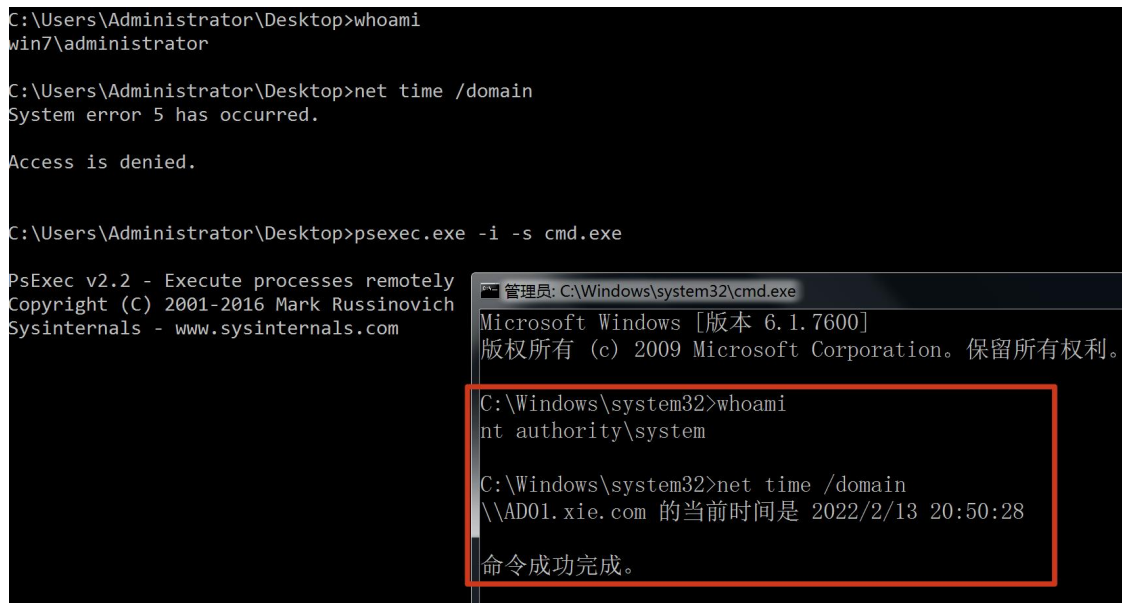
C:\Users\Administrator\Desktop>net time /domain
System error 5 has occurred.

Access is denied.
```

然后我们使用 psexec.exe 工具执行如下命令获取 system 权限之后再进行域查询。

```
psexec.exe -i -s cmd.exe
```

如图所示，当使用 psexec 获得 system 权限后即可成功进行域查询。



```
C:\Users\Administrator\Desktop>whoami
win7\administrator

C:\Users\Administrator\Desktop>net time /domain
System error 5 has occurred.

Access is denied.

C:\Users\Administrator\Desktop>psexec.exe -i -s cmd.exe

PsExec v2.2 - Execute processes remotely
Copyright (C) 2001-2016 Mark Russinovich
Sysinternals - www.sysinternals.com

管理员: C:\Windows\system32\cmd.exe
Microsoft Windows [版本 6.1.7600]
版权所有 (c) 2009 Microsoft Corporation。保留所有权利。

C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>net time /domain
\\AD01.xie.com 的当前时间是 2022/2/13 20:50:28

命令成功完成。
```

使用 impacket 工具远程连接进行域查询

使用 impacket 工具执行如下命令使用 administrator 帐户密码远程连接 win7 获取 system 权限进行域查询。注意这里不能用 win7\$ 机器账号进行远程连接，因为机器账号没有权限连接。

```
python3 smbexec.py administrator:root@10.211.55.6 --codec gbk
```

如图所示，获得 win7 机器的 system 权限，并成功执行域查询。

```

→ examples git:(master) * python3 smbexec.py administrator:root@10.211.55.6 -codec gbk
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>net time /domain
\\AD01.xie.com 的当前时间是 2021/12/29 20:51:19

命令成功完成。

```

使用 adfind 工具查询

可以使用 adfind 工具执行如下命令用 win7\$机器账号密码连接域控进行查询。

```

AdFind.exe -h 10.211.55.4:389 -u xie\win7$ -up "ex1kgnQg;,hYrwu Nn0_59Bdz<t
k<]t;nT:1WPA^N1/\]5fW2S>.ji8bG_VHdp#;]wR7Z IH51G/soN2yahW<N1B,<3#@4aJjk
y8-9CdTe*,?*&k32 iOHP" -f "objectcategory=computer" dn

```

如图所示，使用 win7\$机器账号密码连接域控进行查询，查询出了域内所有机器。

```

C:\Users\Administrator\Desktop>AdFind.exe -h 10.211.55.4:389 -u xie\win7$ -up "ex1kgnQg;,hYrwu Nn0_5
9Bdz<tk<]t;nT:1WPA^N1/\]5fW2S>.ji8bG_VHdp#;]wR7Z IH51G/soN2yahW<N1B,<3#@4aJjky8-9CdTe*,?*&k32 iOHP"
-f "objectcategory=computer" dn

AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021

Using server: AD01.xie.com:389
Directory: Windows Server 2012 R2
Base DN: DC=xie,DC=com

dn:CN=AD01,OU=Domain Controllers,DC=xie,DC=com

dn:CN=MAIL,CN=Computers,DC=xie,DC=com

dn:CN=WIN10,CN=Computers,DC=xie,DC=com

dn:CN=WIN7,CN=Computers,DC=xie,DC=com

4 Objects returned

```

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+

成员数量

30+

内容数量

306

运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



官方: [https://docs.microsoft.com/zh-cn/previous-versions/windows/it-pro/windows-server-2003/cc779144\(v=ws.10\)#active-directory-accounts-and-security-groups](https://docs.microsoft.com/zh-cn/previous-versions/windows/it-pro/windows-server-2003/cc779144(v=ws.10)#active-directory-accounts-and-security-groups)

- Local Accounts
- Active Directory Accounts
- Service Accounts
- [https://docs.microsoft.com/zh-cn/previous-versions/windows/it-pro/windows-server-2003/cc779144\(v=ws.10\)#active-directory-accounts-and-security-groups](https://docs.microsoft.com/zh-cn/previous-versions/windows/it-pro/windows-server-2003/cc779144(v=ws.10)#active-directory-accounts-and-security-groups)



謝公子醫藥